

EC-Council

D | F E

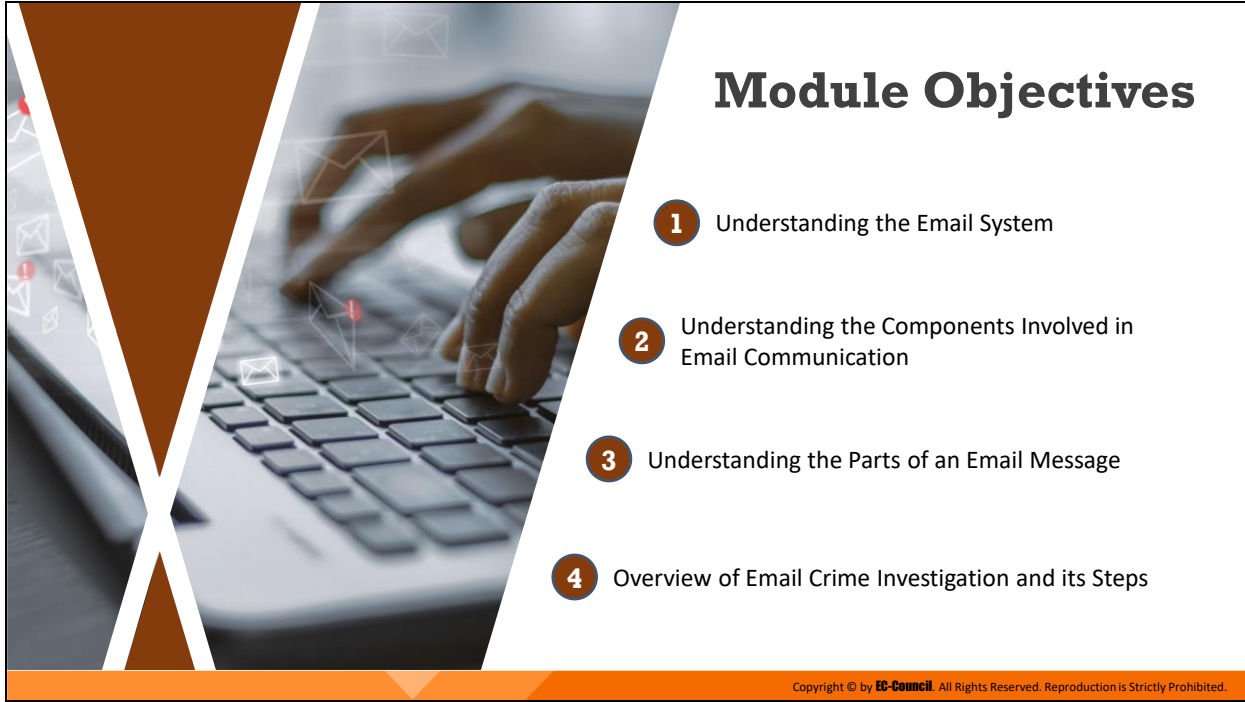
Digital

Forensics Essentials



Module 11

Investigating Email Crimes

A graphic titled "Module Objectives" featuring a background image of hands typing on a laptop keyboard. The image is overlaid with a large, stylized 'X' shape formed by two intersecting diagonal lines, one brown and one white. To the right of the image, the title "Module Objectives" is displayed in a large, bold, black font. Below the title, four numbered objectives are listed, each preceded by a brown circle containing a white number. The objectives are: 1. Understanding the Email System, 2. Understanding the Components Involved in Email Communication, 3. Understanding the Parts of an Email Message, and 4. Overview of Email Crime Investigation and its Steps. At the bottom of the graphic, a small orange bar contains the text "Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited." in a small, black font.

Module Objectives

- 1 Understanding the Email System
- 2 Understanding the Components Involved in Email Communication
- 3 Understanding the Parts of an Email Message
- 4 Overview of Email Crime Investigation and its Steps

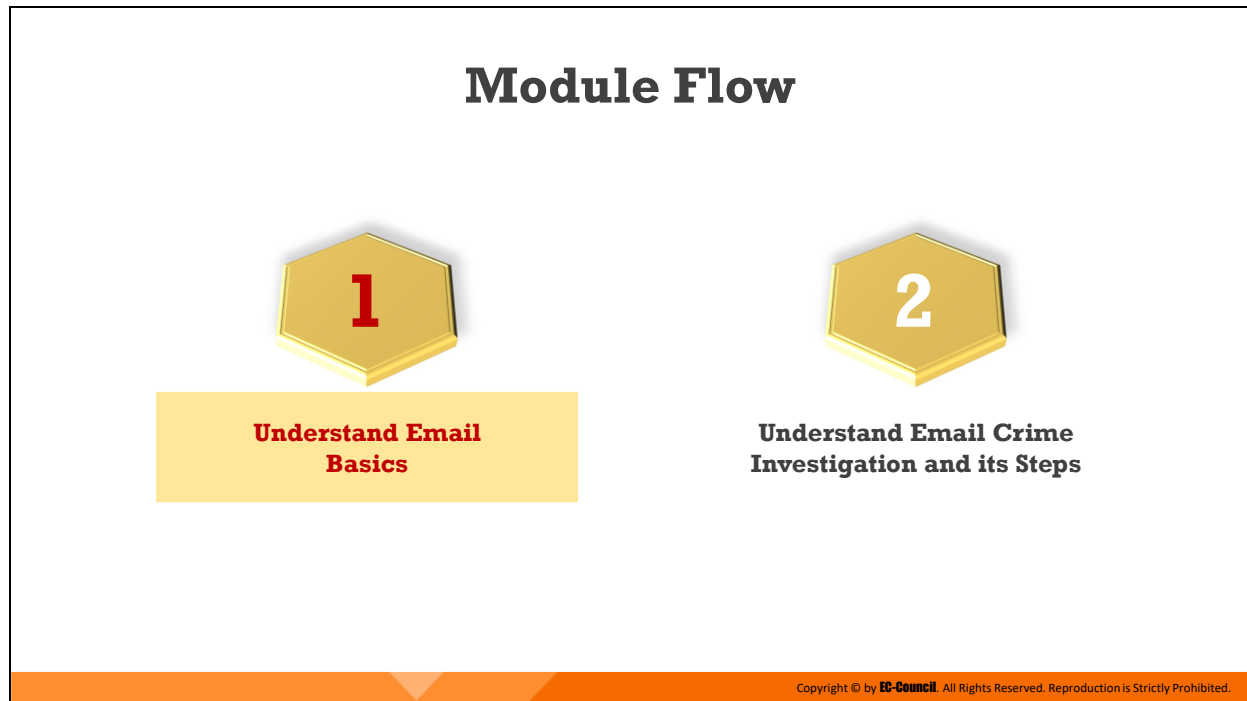
Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Module Objectives

Over the past few decades, email services have been extensively used for communication all over the world for exchanging texts and multimedia messages. However, this has also made email a powerful tool for cybercriminals to spread malicious messages and perform illegal activities. The current module intends to familiarize you with the subject of email crimes and how they occur. It primarily focuses on the steps an investigator needs to follow in an email crime investigation.

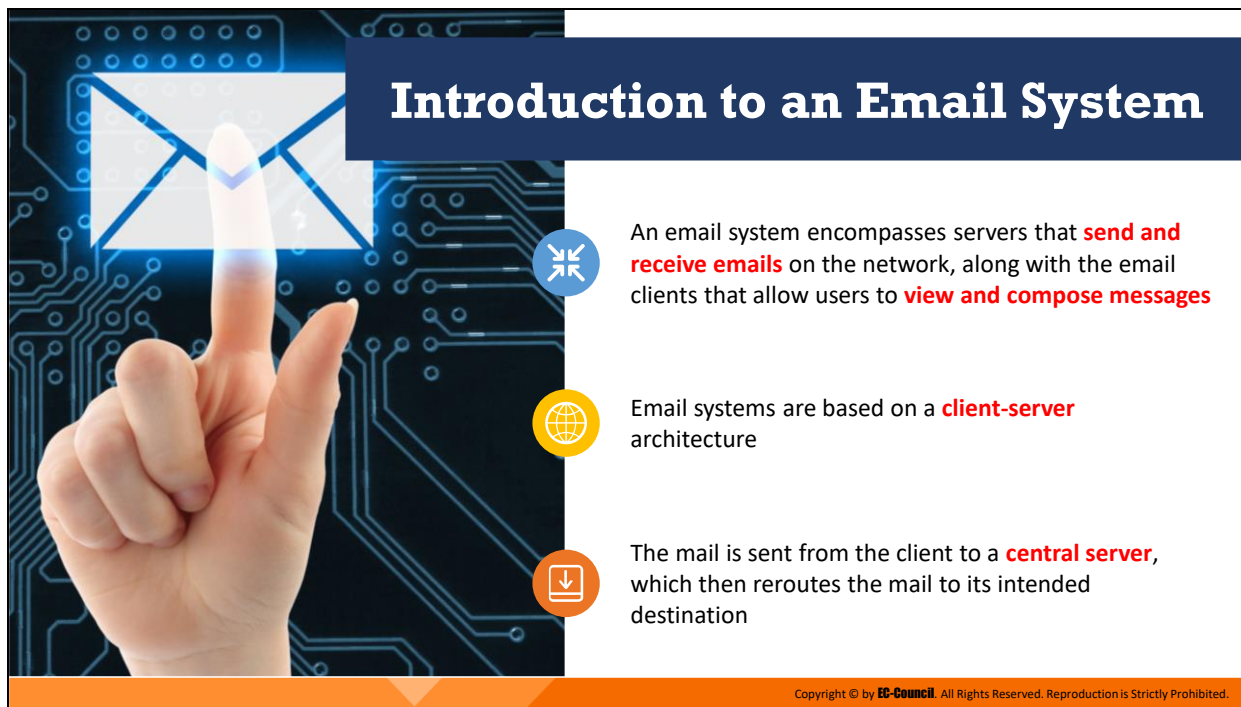
At the end of this module, you will be able to:

- Understand the email system
- Understand the components involved in email communication
- Understand the parts of an email message
- Understand email crime investigation and its steps



Understand Email Basics

An increasing number of enterprises are now using email as their primary communication mode. The growing dependence on emails has also given rise to email crimes. Therefore, forensic investigators need to have a complete understanding of an email system and its inner architecture, along with the components that work together to deliver an email from a sender to recipients. This section discusses the fundamentals of an email system.

An infographic titled "Introduction to an Email System" featuring a hand pointing at a glowing envelope icon on a circuit board background. The infographic lists three key points about email systems: 1. Servers send and receive emails, and clients view and compose messages. 2. Email systems use a client-server architecture. 3. Mail is sent from the client to a central server, which then reroutes it to the destination.

Introduction to an Email System

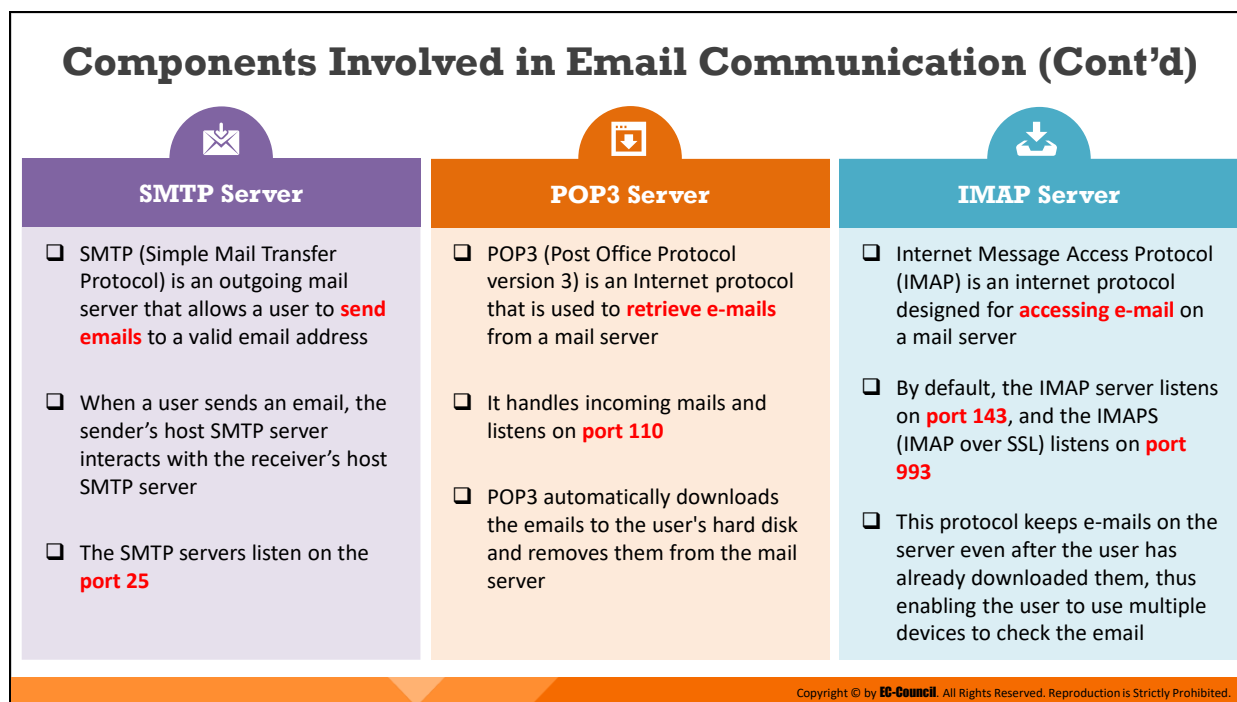
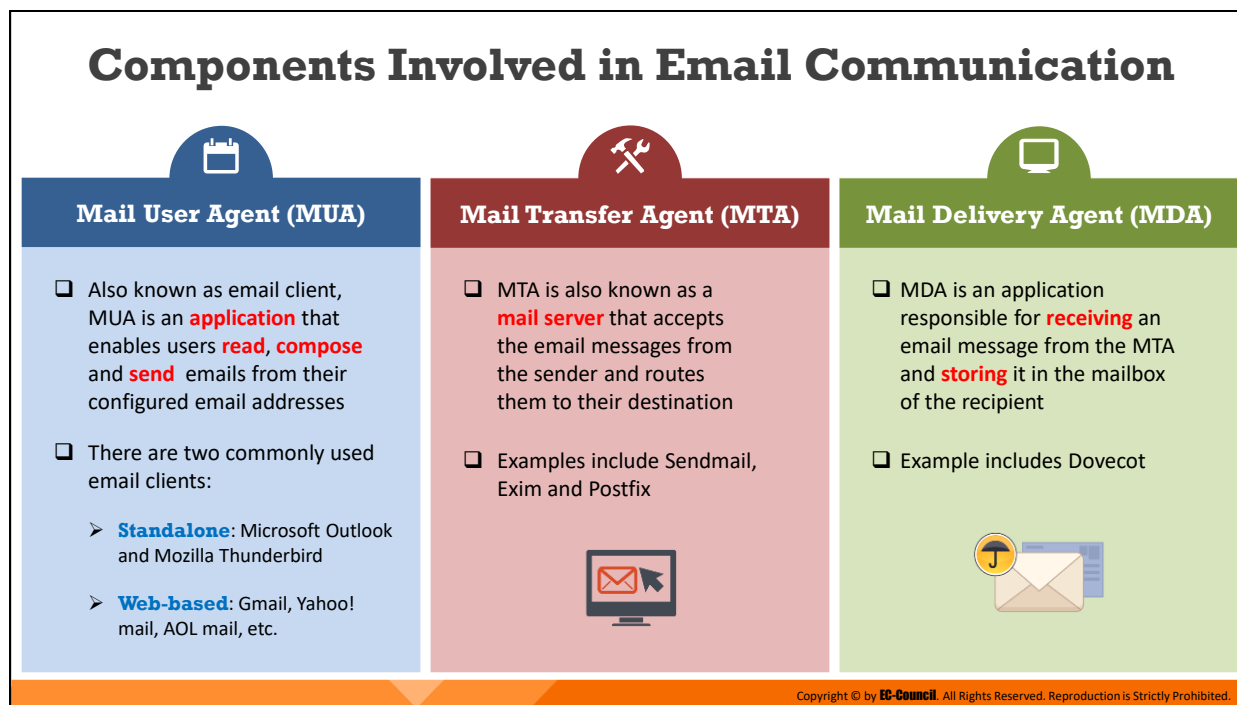
- An email system encompasses servers that **send and receive emails** on the network, along with the email clients that allow users to **view and compose messages**
- Email systems are based on a **client-server** architecture
- The mail is sent from the client to a **central server**, which then reroutes the mail to its intended destination

Copyright © by **EC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Introduction to an Email System

Email is an abbreviation of “electronic mail,” which is used for sending, receiving, and saving messages over electronic communication systems. With growing reliance on technology, email has become one of the most popular modes of communication.

An email system works on the basic client–server architecture. It allows clients to send/receive mails via email servers that communicate with one another. Most email systems have text editors with basic formatting options that enable clients to compose text messages and send them to one or more recipients. Once the message has been sent, it passes through several servers and is stored in the mailbox of the recipient until he/she retrieves it.



Components Involved in Email Communication

There are several components of email communication that play specific roles when an email message is transmitted from a sender to a recipient.

- **Mail User Agent:** Also known as an email client, mail user agent (MUA) is a desktop application for reading, sending, and organizing emails. It provides an interface for users to receive, compose, or send emails from their configured email addresses.

A user needs to set up and configure their email address before using the email client. The configuration includes issuing email IDs, passwords, Post Office Protocol version 3 (POP3)/ Internet Message Access Protocol (IMAP) and Simple Mail Transfer Protocol (SMTP) address, a port number, and other related preferences. There are many standalone and web-based email clients such as Claws Mail, Thunderbird, Mailbird, Zimbra Desktop, Gmail, and Outlook.com. The email client becomes active only when the user runs it.

- **Mail Transfer Agent:** Mail transfer agent (MTA) is an important component of the email transmission process. It is primarily a type of mail server that receives the email message from the mail submission agent and decrypts the header information to see where the message is going. Once determined, it passes on the message to the next MTA server.

All the MTA servers talk to each other via the SMTP protocol. Some examples of MTA include Sendmail, Exim, and Postfix.

- **Mail Delivery Agent:** Mail delivery agent (MDA) is the server that receives the email message from the last MTA and keeps it in the mailbox of the recipient. Dovecot is an example of an MDA.
- **SMTP Server:** The SMTP is an outgoing mail server that allows a user to send emails to a valid email address. Users cannot use the SMTP server to receive emails; however, in conjunction with the Post Office Protocol (POP) or IMAP, they can use the SMTP to receive emails with proper configuration.

Any SMTP server is assigned an address by the mail client of the user in the following format: smtp.serveraddress.com (for example, SMTP server address of Gmail would be smtp.gmail.com).

When a user sends an email to a specific recipient, it first reaches the SMTP server that processes the message to determine the address of the recipient and then relays it to the particular server. All SMTP servers generally listen to port 25. However, outgoing SMTP servers use port 587 for transport layer security connections and port 465 for secure sockets layer (SSL) connections.

- **POP3 Server:** POP3 is a simple protocol for retrieving emails from an email server. When the POP server receives emails, they are stored on the server until and unless the user requests it.

The POP3 server does not allow the concept of folders; it considers the mailbox on the server to be its sole store. Once the user connects to the mail server to recover their mail using the email client, the mails are automatically downloaded from the mail server to the user's hard disk and are no longer stored on the server unless the user specifies to keep a copy of it.

The POP3 server can understand simple commands such as the following:

- **USER** – enter your user ID
- **PASS** – enter your password

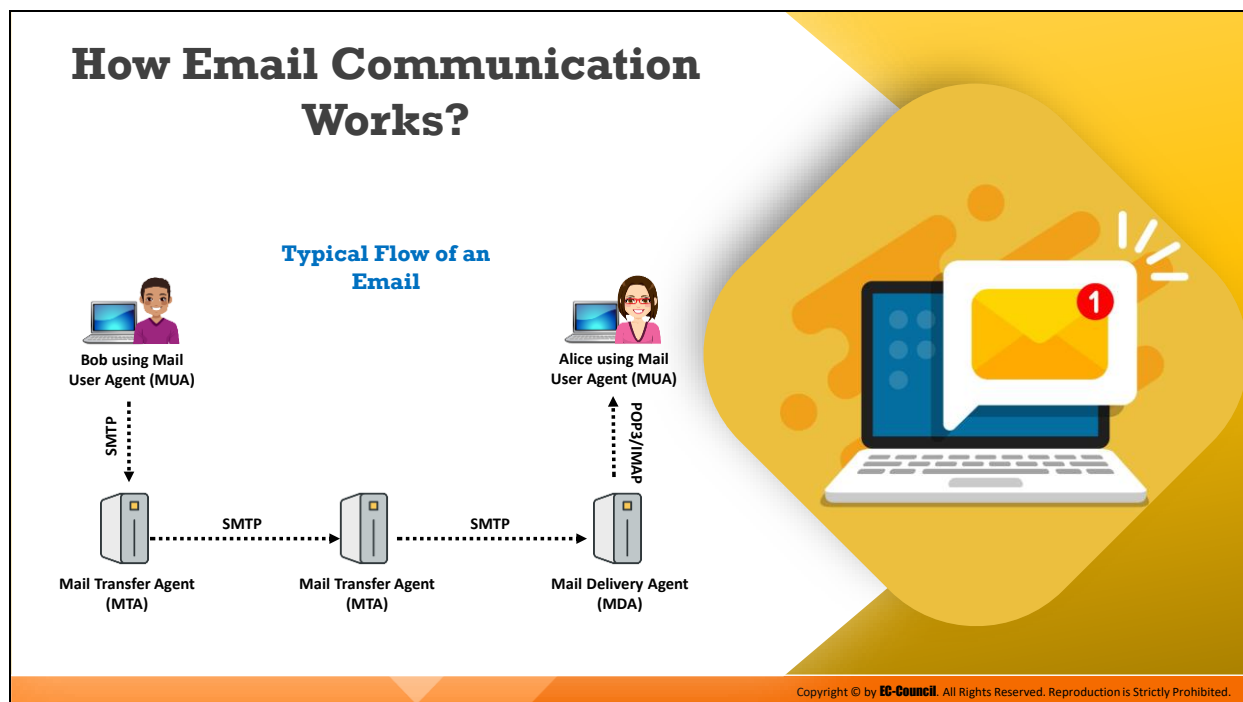
- **QUIT** – quit the POP3 server
- **LIST** – list the messages and their size
- **RETR** – retrieve a message, according to a message number
- **DELETE** – delete a message, according to a message number

Since POP3 implemented email clients download mails onto the system, a user can read mails even when there is no Internet connectivity. However, because the mails are stored on the hard drive, users cannot access them from remote machines.

- **IMAP Server:** IMAP servers are similar to POP3 servers. Like POP3, IMAP handles the incoming mail. By default, the IMAP server listens to port 143 and the IMAPS (IMAP over SSL) listens on port 993.

IMAP stores emails on the mail server and allows users to view and work on their emails, as if the mails are stored in their local systems. This enables users to organize all the mails depending on their requirements. In contrast with POP3, IMAP does not move the mail server to the user's mailbox.

It acts as a remote server that stores all the user's mails in the mail server. IMAP allows email clients to retrieve multi-purpose Internet mail extensions (MIME) parts either in the form of an entire message or in multiple bits, allowing the clients to retrieve only the text part of the mail without downloading the attachment. This protocol stores a copy of all the emails on the server even if the user downloads them onto their system. As a result, users can access them from any computing system or device.



How Email Communication Works

When a user sends an email message to any recipient, it goes through several stages before it reaches its destination. A scenario is presented below to elaborate on these stages:

- Consider that an email user named Bob wants to send an email message to another email user named Alice. He composes a message using his email client or MUA or a web-based email like Yahoo!, specifies the email address of Alice, and hits the send button.
- The email message is received by an MTA server via SMTP that decrypts the header information and searches for the domain name in Alice's email address. This method allows the MTA server to determine the destination mail server and pass on the message to the corresponding MTA.
- Each time an MTA server receives a message during the mail delivery process, it modifies its header information. When it reaches the last MTA, it is transferred to the MDA, which keeps the message in Alice's mailbox.
- Alice's MUA then retrieves the message using either POP3 or IMAP, and Alice is finally able to read the message.

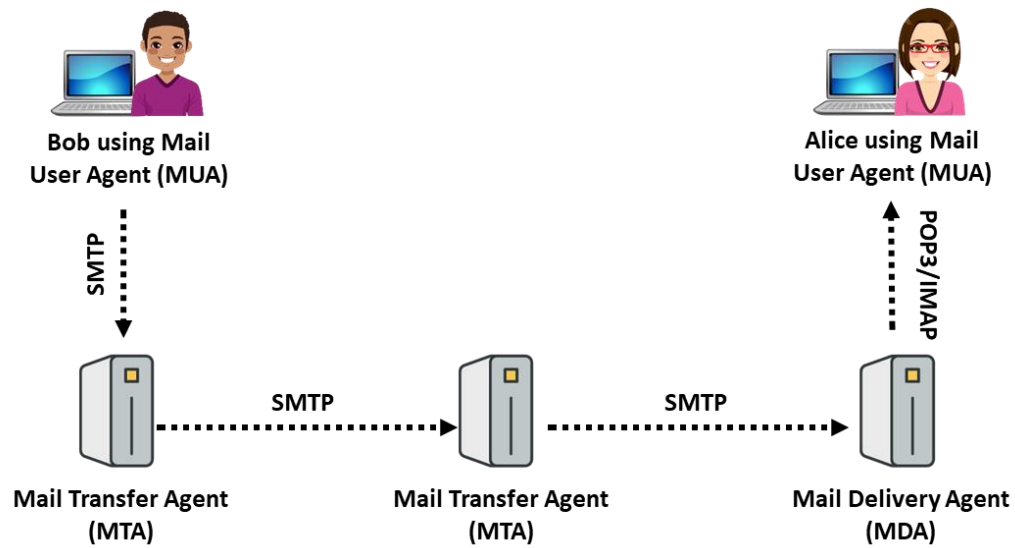


Figure 11.1: How email communication works

Understanding the Parts of an Email Message

From: Maria Wilson <mary79@abc.edu>
Date: 02 April 2020 19:52
To: ford90hen@outlook.com
Subject: When can we meet again?

Hello Henry,
When can we get together to work on our project? I am available any time this week after 5:00 PM. But I do have some other appointments next week. I would like to meet before we have our next class, so email me and let me know what would work for you.
Thanks!

Regards,
Maria Wilson
Assistant Professor, Language Department
ABC College

Header

- Email headers contain **information** about the **email origin** such as the address from which it came, the routing, time of the message, and the subject line
- Examples include To, Cc, Bcc, From, Message-Id, Reply-To, Sender, Subject, MIME-Version, and Priority

Body

- This part contains the **actual message** sent via the email either in HTML or plain-text
- It may include images and hyperlinks

Signature

- This provides information to the **recipients** about the identity or designation of the sender



Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Understanding the Parts of an Email Message

The email message is a brief and informal text sent or received over a network. Email messages are simple text messages that can also include attachments such as image files and spreadsheets. Multiple recipients can receive email messages at a time.

At present, RFC 5322 defines the Internet email message format and RFC 2045 through RFC 2049 defines multimedia content attachments—together these are called multi-purpose Internet mail extensions (MIME).

Email messages comprise three main sections:

1. Message header

The message header includes the following fields:

- **To** specifies to whom the message is addressed. Note that the “To” header does not always contain the recipient’s address.
- **Cc** stands for “carbon copy.” This header specifies additional recipients beyond those listed in the “To” header. The difference between “To” and “Cc” is essentially connotative; some mailers also deal with them differently in generating replies.
- **Bcc** stands for “blind carbon copy.” This header sends copies of emails to people who might not want to receive replies or appear in the headers. Blind carbon copies are popular with spammers because they confuse many inexperienced users who receive an email that does not have their address or does not appear to be for them.
- **From** specifies the sender of the message

- **Reply-To** specifies an address for sending replies. Though this header has many legitimate uses, it is also widely used by spammers to deflect criticism. Occasionally, a native spammer will solicit responses by email and use the “Reply-To” header to collect them, but more often, the address specified in junk email is either invalid or that of an innocent victim.
- **Sender** is unusual in email (“X-Sender” is usually used instead) but appears occasionally, especially in copies of Usenet posts. It should identify the sender; in the case of Usenet posts, it is a more reliable identifier than the “From” line.
- **Subject** is a completely free-form field specified by the sender to describe the subject of the message
- **Date** specifies the date of creation and sending of the email. If the sender’s computer omits this header, a mail server or some other machine might conceivably add it, even along the route.
- **MIME-Version** is another MIME header that reflect MIME protocol’s version
- **Priority** is an essentially free-form header that assigns a priority to the mail. Most of the software ignore it. Spammers often use it in an attempt to get their messages read.

2. Message Body

The body of the email conveys the message and sometimes includes a signature block at the end. A blank line separates the header and body. In an email, the body or text always comes after the header lines.

The email body is the main message of the email that contains text, images, hyperlinks, and other data (like attachments). The email body displays separate attachments that appear in line with the text. The Internet email standard has not set any limitations on the size of an email’s body. However, individual mail servers have message size limits.

3. Signature

An email signature is a small amount of additional information attached at the end of the email message that consists of the name and contact details of the email sender. It can contain plain text or images.



Figure 11.2: Parts of an email message

Module Flow



**Understand Email
Basics**

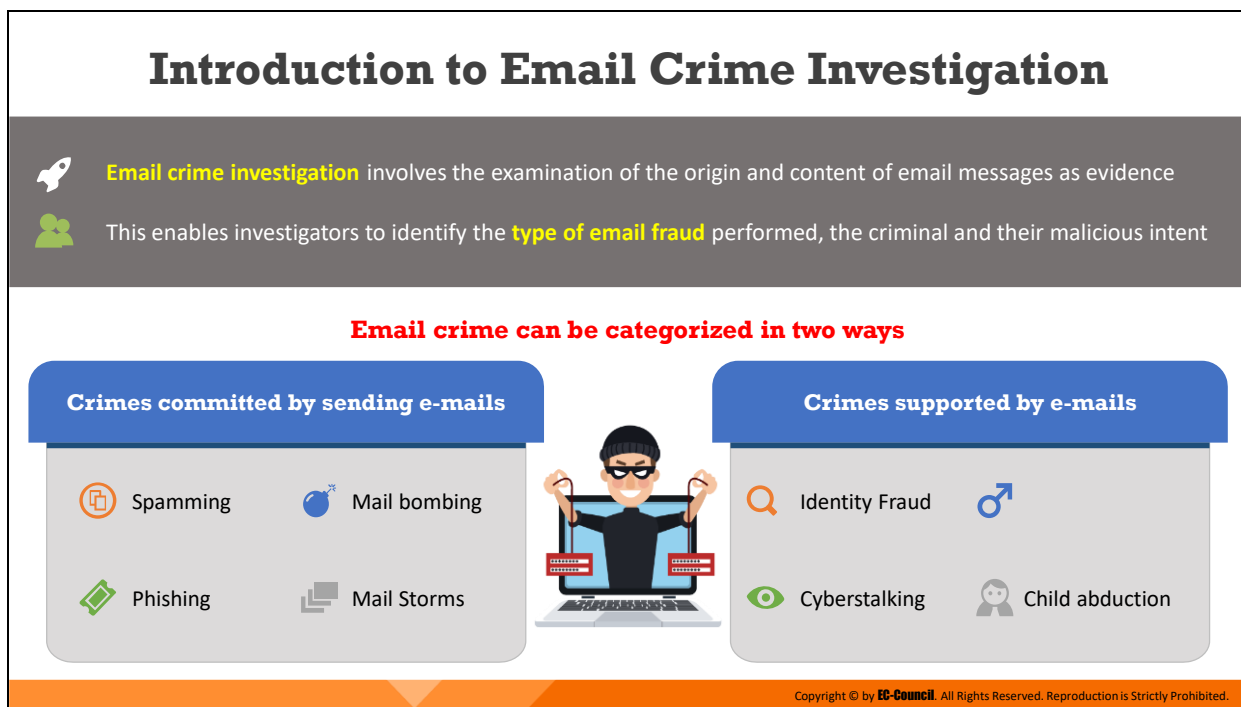


**Understand Email Crime
Investigation and its Steps**

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Understand Email Crime Investigation and its Steps

Email crime investigation is primarily conducted to examine the content as well as the origin of any email message that is found to be offensive or suspected to be spoofed. This section defines email crime investigation and elaborates on the steps that investigators need to follow while probing into email crimes.



Introduction to Email Crime Investigation

Email crime investigation involves the extraction, acquisition, analysis, and revival of email messages related to any cybercrime. Detailed analysis of email messages helps investigators gather useful evidence such as the date and time when the email message was sent, the actual IP address of the sender and recipient, and what spoofing mechanism was used. Investigators need to use many forensic tools to extract metadata from email headers. This helps them locate the criminal behind the crime and report the findings in order to prosecute them in the court of law.

Investigations of criminal activities or violations of policies related to emails are similar to other kinds of computer crime investigations. Email crimes can be categorized in two ways: one committed by sending emails and the other supported by email. When criminals use spam, fake email, mail bombing, or mail storms to sell narcotics, stalk, commit fraud, or commit child abduction, it can be said that those emails support cybercrime.

Let us discuss in detail the crimes committed by sending emails.

- **Email Spamming**

Spam is unsolicited by commercial or junk email. Spam mail involves sending the same content to a huge number of addresses at the same time. Spamming or junk mail fills mailboxes and prevents users from accessing their regular emails. These regular emails start bouncing because the server exceeds its capacity limit. Spammers hide their identities by forging the email header. To avoid obtaining responses from annoyed receivers, spammers provide misleading information in the FROM and REPLY-TO fields and post them to a mailing list or newsgroup.

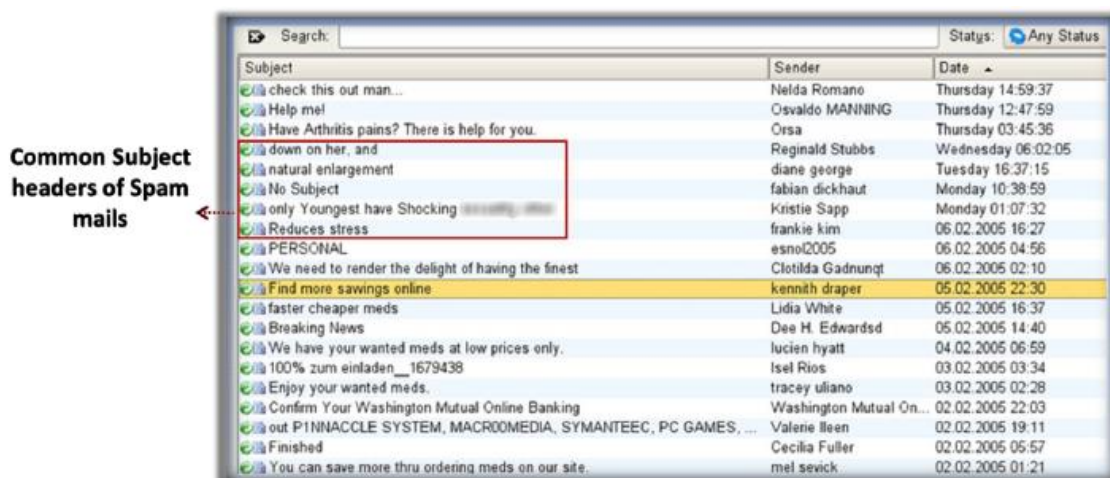


Figure 11.3: Subject headers of spam emails

■ Phishing

Phishing has emerged as an effective method for stealing personal and confidential data of users. It is an Internet scam that tricks users into divulging their personal and confidential information by making interesting statements and offers. Phishers can attack users by mass mailing to millions of email addresses worldwide.

The phishing attack deceives and convinces the user with fake technical content along with social engineering practices. The major task for phishers is to make the victims believe that the phishing sites are legitimate. The sources that can be impersonated include web pages, instant messaging, emails, and Internet Relay Chat. Most phishing attacks are done through emails, where the user gets an email that tricks the user to follow the given link, navigating them to a phishing website. The email may contain a message stating that a particular transaction has occurred from the user's account and may have a link to check their balance, or it may contain a link to perform a security check for the user's account.

Following are given some types of phishing attacks:

- **Spear Phishing** is when, instead of sending thousands of emails, some attackers use specialized social engineering content directed at a specific employee or a small group of employees in a specific organization to steal sensitive data such as financial information and trade secrets. Spear phishing messages seem to be from a trusted source with an official-looking website. The email also appears to be from an individual from the recipient's company, generally someone in a position of authority. However, the message is actually sent by an attacker attempting to obtain critical information about a specific recipient and their organization, such as login credentials, credit card details, bank account numbers, passwords, confidential documents, financial information, and trade secrets. Spear phishing generates a higher response rate compared with a normal phishing attack, as it appears to be from a trusted company source.

- **Whaling** is a type of phishing attack that targets high-profile executives such as CEOs, CFOs, politicians, and celebrities who have complete access to confidential and highly valuable information. It is a social engineering trick in which the attacker tricks the victim to reveal critical corporate and personal information (such as bank account details, employee details, customer information, and credit card details), generally through email or website spoofing. Whaling is different from a phishing attack; in this case, the email or website that is used for the attack is carefully designed to target someone in the executive leadership in particular.
- **Pharming** is a social engineering technique in which an attacker executes malicious programs on a victim's computer or server. When the victim enters any URL or domain name, it automatically redirects the victim's traffic to a website controlled by the attacker. This attack is also known as "Phishing without a Lure": The attacker steals confidential information such as credentials, banking details, and other information related to web-based services. Pharming attacks can be performed in two ways, namely, Domain Name System (DNS) cache poisoning and host file modification.
- **Spimming** or "spam over instant messaging" (SPIM) exploits instant messaging platforms and uses IM as a tool to spread spam. A person who generates spam over IM is called a spimmer. A spimmer generally makes use of bots (an application that executes automated tasks over the network) to harvest instant message IDs and forwards the spam message to them. SPIM messages, similar to email spams, generally include advertisements and malware as an attachment or embedded hyperlink. A user who clicks the attachment gets redirected to a malicious website, which collects financial and personal information such as credentials, bank accounts, and credit card details.

▪ **Mail Bombing**

Email bombing refers to the process of repeatedly sending an email message to a particular address at a specific victim's site. In many instances, the messages will be filled with junk data aimed at consuming more system and network capacity.

Multiple accounts at the target site may be abused, increasing the denial of service impact. Mail bombing is an intentional act of sending multiple copies of identical content to the same recipient. The primary objective behind it is to overload the email server and degrade the communication system by making it unserviceable. Usually, a mail bomber and the victim know each other. Newsgroup postings that do not agree with the recipient's opinion also result in mail bombing. The target in such cases can be either a specific machine or a particular person. Mail bombing is more abusive than spamming because it not only sends mails in excessive amounts to an individual but also prevents other users from accessing their email using the same server.

▪ **Mail Storms**

A mail storm occurs when computers start communicating without human intervention. The flurry of junk mail sent by an accident is a mail storm. Usage of mailing lists, auto-forwarding emails, automated response, and the presence of more than one email

address are the various causes of a mail storm. Malicious software code is also written to create mail storms such as the “Melissa, I-Care-For-U” message. Mail storms hinder communication systems and make them inoperable.

Let us now focus on the crimes supported by emails.

- **Identity Fraud**

Identity fraud is the illegitimate retrieval and use of others’ personal data for malicious and monetary gains. Identity theft is a crime that is quickly gaining popularity. It is the willful act of stealing someone’s identity for monetary benefits. Criminals obtain personal information about a person and misuse it, causing heavy financial loss to the victim. Online shopping sites that have false representations and spam emails that contain irresistible offers are the common means used to obtain the victim’s credit card numbers. Once the user has placed an order online, criminals can intercept the email message and use it. Criminals not only withdraw huge amounts of money from the victims’ accounts but can also make the victim bankrupt.

- **Cyberstalking**

Cyberstalking is a crime where attackers harass an individual, a group, or an organization using emails or IMs. Attackers try to threaten, make false accusations, defame, slander, libel, or steal the identity of the victim/victims as a part of cyberstalking. The stalker can be someone associated with a victim or a stranger.

- **Child Abduction**

Child abduction is the offense of wrongfully removing or retaining, detaining, or concealing a child or baby. Abduction is defined as taking away a person by persuasion, fraud, or open force or violence. There are two types of child abduction: parental child abduction and abduction by a stranger. Parental child abductions are the most common type, while abduction by a stranger will be categorized as kidnapping.



Steps to Investigate Email Crimes

To be able to find, extract, and analyze email-related evidence, an investigator must follow a series of defined and practiced steps. This will not only ease the process of gathering evidence but also help the investigator maintain compliance and integrity.

Some of the vital steps to be followed while conducting an email crime investigation are as follows:

1. Seizing the computer and email accounts
2. Acquiring the email data
3. Examining email messages
4. Retrieving email headers
5. Analyzing email headers
6. Recovering deleted email messages

Step 1: Seizing the Computer and Email Accounts



- ✓ Obtain a **search warrant** that should include permission to perform on-site examination of the suspect's computer and the email server used to send the emails under investigation
- ✓ Seize all computers and email accounts **suspected** to be involved in the crime
- ✓ You can **seize the email accounts** by changing the existing password of the e-mail account, either by asking the suspect his or her password or obtaining it from the mail server

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Step 1: Seizing the Computer and Email Accounts

To carry out on-site examination of the computer and email server, an investigator should obtain a search warrant application in the appropriate language. Then, they should conduct a forensics test on the permitted equipment, as mentioned in the warrant. All computers and email accounts suspected to be involved in the crime should be seized. The investigator can seize the email accounts by changing its existing password—either by asking the victim's password or obtaining it from the mail server.

If the victim is a corporate organization, then the investigator should obtain permission from the concerned authorities and collaborate with the internal network and system administrators to understand their policies and abide by their data safety regulations.

Step 2: Acquiring the Email Data



- ☐ The next step in an email crime investigation is to **acquire the email data** for forensic analysis
- ☐ Before acquiring email data, the investigator should consider the following scenarios:
 - The suspect accesses his/her emails via any **desktop-based email client**
 - The suspect has an **web-based email** account on which the crime has occurred
- ☐ The email data acquisition methods would be different for each scenario

Copyright © by **EC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Step 2: Acquiring the Email Data

Once the computer and email accounts have been seized, the next step is to acquire the email data for forensic analysis. The acquisition of email data depends on the following scenarios:

- The suspect has been accessing emails via desktop-based email clients such as Outlook and Mozilla Thunderbird
- The suspect has a web-based email account that they accessed via the browser

The investigator needs to choose the acquisition process as per the situation in the crime scene.

Acquiring Email Data from Desktop-based Email Clients



When an email crime is suspected to have occurred on a user's machine using email clients, the key sources of evidence are the **local folders and archived files** stored by these programs that hold information regarding all email activities



Forensic investigators need to locate the local folders and recover the email messages using the **right forensic tools** for further examination



While acquiring email data from the local archives, **investigators must be careful** to gather all the files as local archives can be spilt into multiple files that store data separately



Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Acquiring Email Data from Desktop-based Email Clients

Many users prefer desktop-based email clients such as Microsoft Outlook, Mozilla Thunderbird, and Apple mail to send/receive emails. When an email crime is suspected to have occurred on a user's machine using email clients, the key sources of evidence are the local folders and archived files stored by these programs that hold information on all email activities. The job of the forensic investigator is to locate the local folders and extract all email messages using the right forensic tool and store the copies in a safe location.

Local email files/databases created by email clients can be saved in various locations on the suspect's computer. The investigator needs to carefully identify all the local email files and acquire the relevant email messages related to the crime.

Local Email Files in Microsoft Outlook

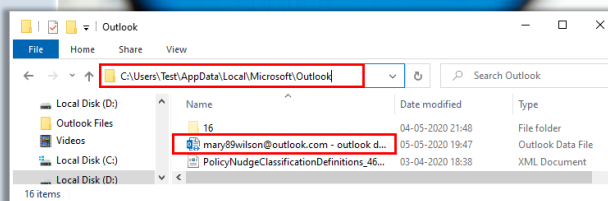
- ❑ When users **configure** their **email accounts** on Outlook, it creates a local copy of all the email information in two kinds of file formats:

Personal Storage Table (.pst)

- ❖ Certain kinds of POP accounts use the .pst file to save mailbox information on the local computer
- ❖ By default, .pst files are stored at
C:\Users\%USERNAME%\Documents\Outlook Files

Offline Storage Table (.ost)

- ❖ Account types such as Microsoft Exchange, Office 365 and IMAP accounts store a copy of the mailbox components in an .ost file
- ❖ By default, .ost files are located at
C:\Users\%USERNAME%\AppData\Local\Microsoft\Outlook



Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Local Email Files in Microsoft Outlook (Cont'd)



Email artifacts can also be found in the **Archive folder**, which is a default folder created by Outlook along with folders such as Inbox, Drafts, and Sent Items



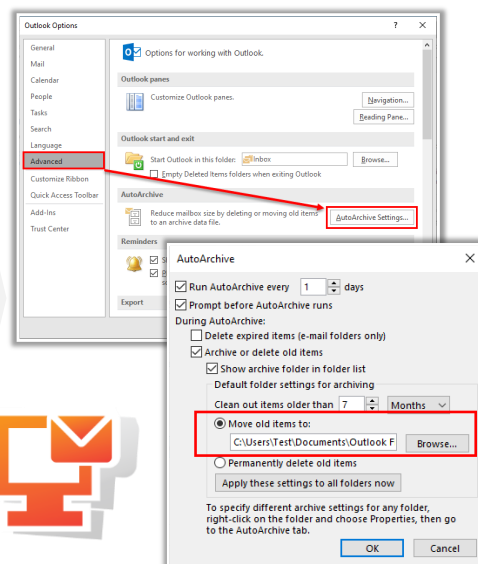
Outlook 2010, 2013 and 2016 have an **Outlook Auto Archive feature** that enables users to move email messages and other important items to an archive folder



To know the Outlook 2016 Auto Archive data location on the suspect's machine, navigate to **File > Options > Advanced > AutoArchive Settings**



Outlook saves the Archived data in **.pst** file format



Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Local Email Files in Microsoft Outlook

When an email account is synced with the Microsoft Outlook desktop application, it creates a local copy of all the email folders in the following two formats:

Personal Storage Table (.pst)

Generally, pop accounts store all the email information in a **.pst** file format in Outlook. The email messages, contact, calendar, and other task data are automatically downloaded

from the mail server and saved locally on the hard disk. In Outlook 2013 and earlier versions, the **.pst** files were used by IMAP accounts. However, in Outlook 2016, email messages of all IMAP accounts are saved in the **.ost** file format. The default location of **.pst** files in Outlook 2016 is **C:\Users\%USERNAME%\Documents\Outlook Files**

▪ Offline Storage Table (.ost)

Account types such as Outlook.com, Outlook for Office 365, Microsoft Exchange, and IMAP copy all mailbox components in the **.ost** file format. As emails, contact, calendar, and other data are not taken off the server such as pop accounts, users can access their emails even when they do not have an Internet connection. All mailbox information is updated when the connection is revived. By default, the **.ost** file in Outlook 2016 is saved at the following location: **C:\Users\%USERNAME%\AppData\Local\Microsoft\Outlook**.

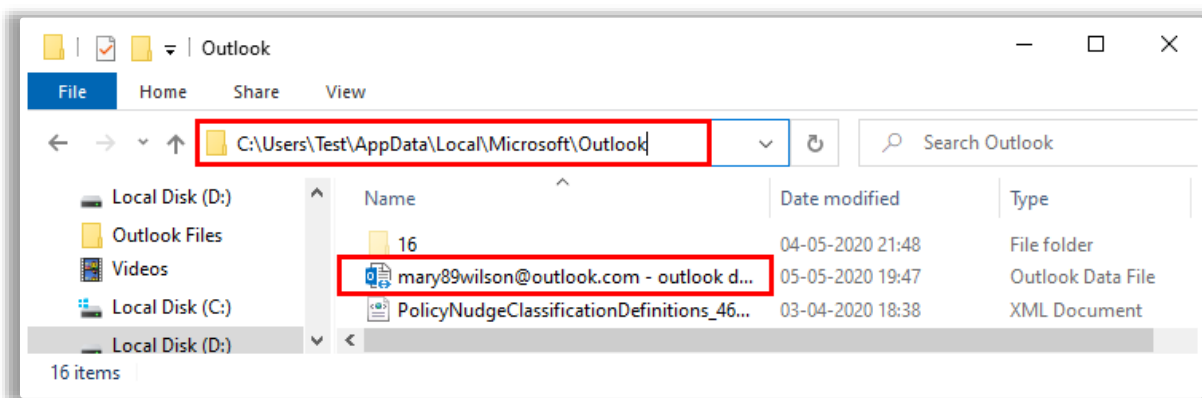


Figure 11.4: .ost File and its location as created by Microsoft Outlook

The investigator can also extract email-related artifacts from archives, a default folder created by the Outlook application that enables users to save old emails. AutoArchive features are available in the Outlook 2013, 2016, and 2019 versions, and they allow users to archive emails automatically at regular intervals. These archive files are stored in the **.pst** format.

To determine the location of the Outlook archive file, the investigator needs to obtain the credentials of the suspect, open the Outlook application, and navigate to **File → Options → Advanced → AutoArchive Settings**.

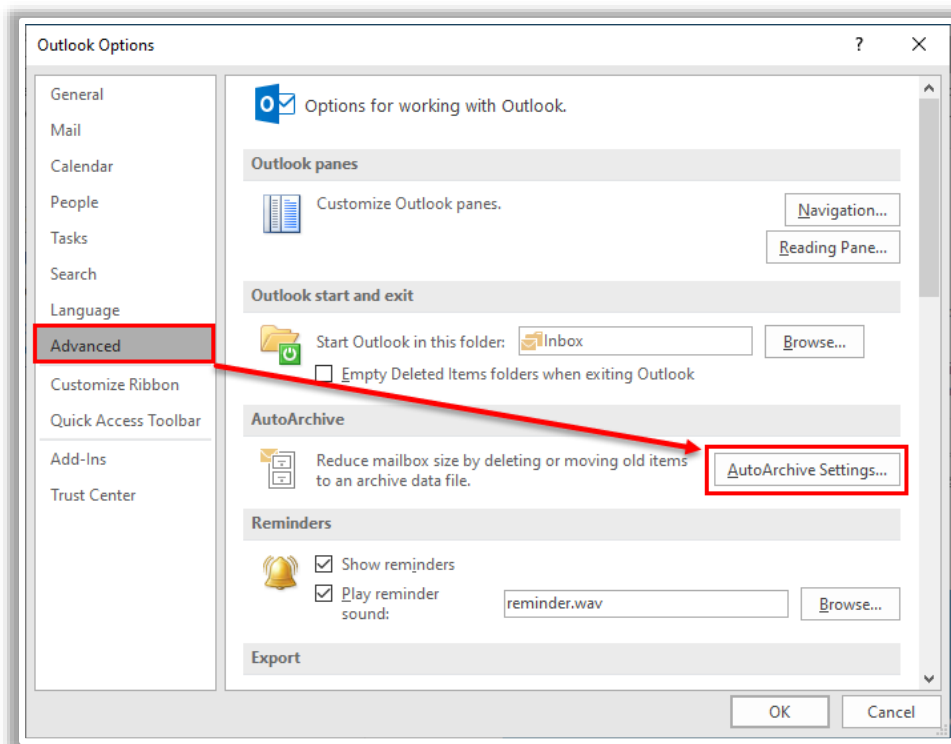


Figure 11.5: Navigating to AutoArchive Settings in Microsoft Outlook

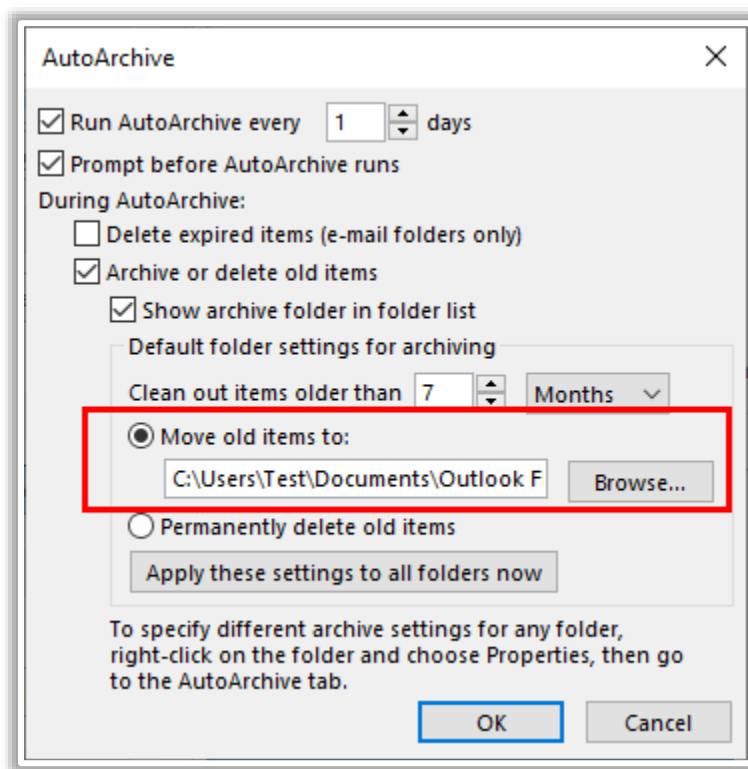
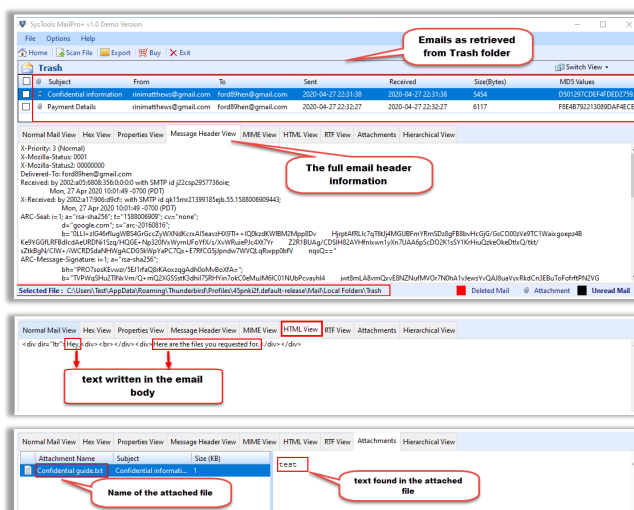


Figure 11.6: Finding the location of Archive folder in Outlook

Acquiring Thunderbird Local Email Files via SysTools MailPro+

- Use tools such as SysTools MailPro+ to **examine local mail files and folders** and collect them as evidence
- You can select one or more mbox files or specific local email folders for forensic acquisition and analysis
- Mailpro+** offers six different views to look at the messages extracted from the Thunderbird local folders

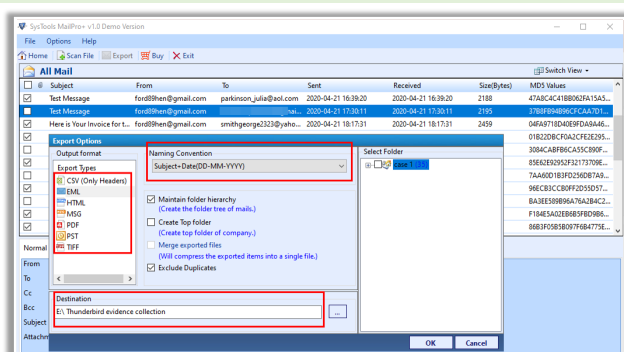


<https://www.systoolsgroup.com>

Copyright © by **EC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Acquiring Thunderbird Local Email Files via SysTools MailPro+ (Cont'd)

- Select all email messages of evidentiary value and click the **'Export'** button to acquire them
- You can select the exported file type and name format and collect the selected email messages in the chosen destination folder



<https://www.systoolsgroup.com>

Copyright © by **EC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Acquiring Thunderbird Local Email Files via SysTools MailPro+

As a forensic investigator, you can use tools such as SysTools MailPro+ to acquire local email file data as stored by Thunderbird. They can select one or more mbox files or specific local email folders for forensic acquisition and analysis. The figures below show the acquisition of the Trash folder of a suspect email account using SysTools MailPro+

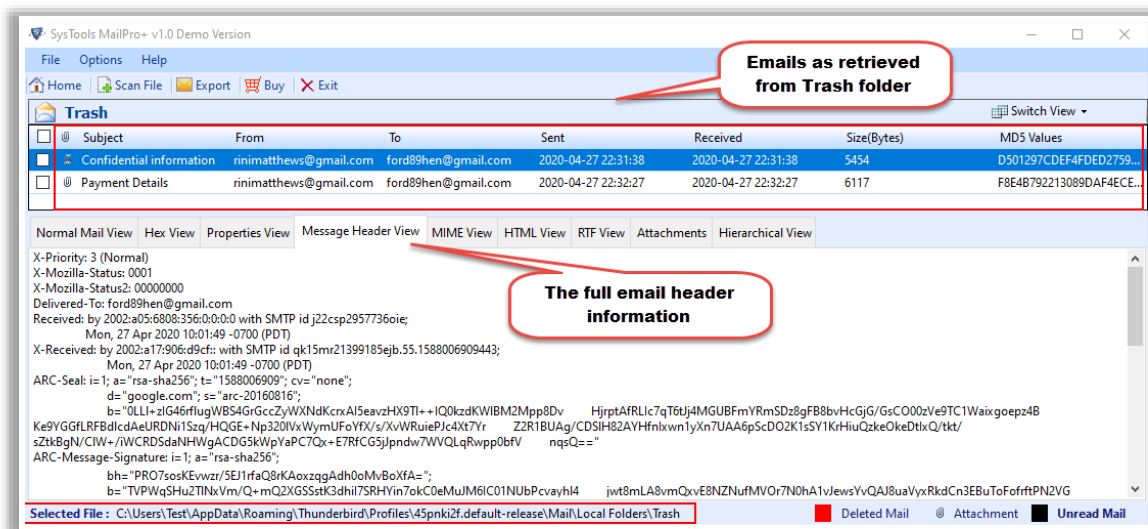


Figure 11.7: Analyzing Emails retrieved from the Trash Folder of a suspect email account

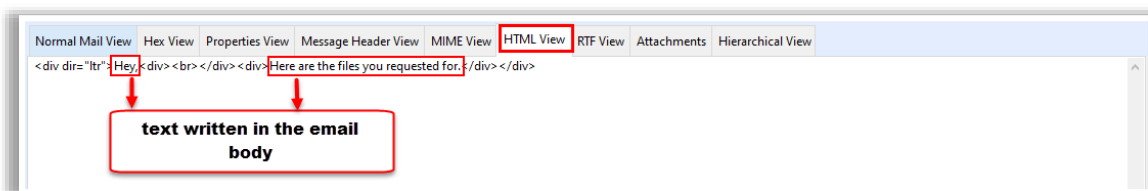


Figure 11.8: Examining the HTML View of an email message retrieved from a suspect email account



Figure 11.9: Retrieving attachment from an email message retrieved from a suspect email account

Select all email messages of evidentiary value and click the 'Export' button to acquire them. You can select the exported file type and name format and collect the selected email messages in the chosen destination folder.

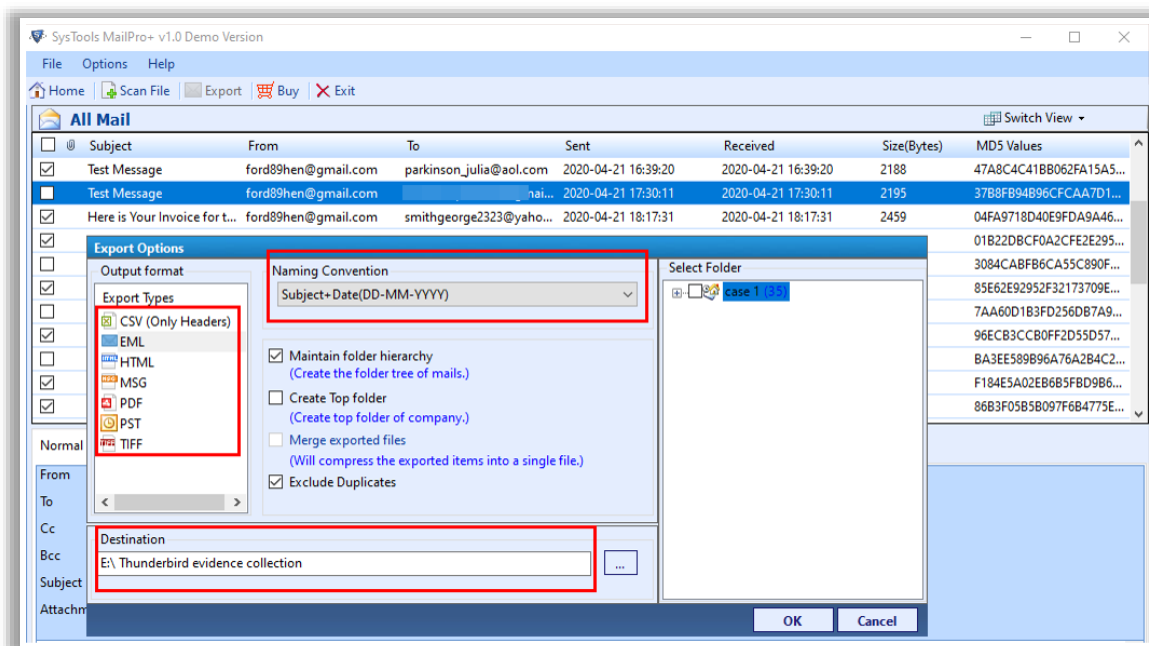


Figure 11.10: Selecting Output format, Destination and Naming Convention while exporting retrieved email messages

SysTools Mailpro+

Source: <https://www.systoolsgroup.com>

It is a versatile and all-rounder utility to preview, search, and export emails from multiple email clients.

Features

- Supports more than 12 email file formats
- Read the mailbox of any email file type
- Search emails within source email files in just a few clicks
- Create and save collections for easy mailbox management
- Search and extract emails from hard drive or external storage
- Add files in three modes to the software's dashboard
- Export emails into .pst, .pdf, .msg, .html, .eml, .tiff, and .csv file types
- Preview attachment types such as JPG, GIF, PNG, DOC, and PDF

Previewing Emails

This tool provides a preview of emails in various modes such as given below:

▪ Normal Hex View

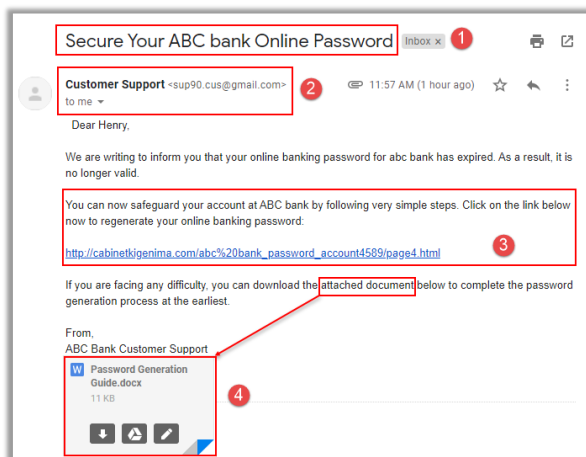
It shows emails along with attributes such as To, CC, BCC, Subject, Date, and Time

- **Hex View**
It shows emails in hex code in a bit-by-bit manner
- **Properties View**
It displays properties associated with emails such as message flags, recipients, and sender
- **Message Header View**
It provides viewing details such as X-Priority, Message ID, Thread-Index, Content-Type, and other information
- **MIME View**
It shows emails in MIME format with various details
- **HTML View**
It displays emails in HTML with all the tags and body
- **RTF View**
- This provides a preview of emails in plain text format
- **Attachments View**
This allows users to view the attachments in emails
- **Hierarchical View**
This shows the hierarchical view of the folder containing the source file

Step 3: Examining Email Messages

While looking at the acquired email messages, you need to closely examine the following areas:

- 1 **Subject**
This field is important as it sums up the **message contained** in that email; most spam email subjects create a sense of urgency, prompting users to open the mail
- 2 **Sender Email Address**
Attackers often **spoof** this address to make it **look legitimate** to the user. You can see here that customer support team at abc bank is using a Gmail account instead of the respective bank domain which is suspicious.
- 3 **Email Body**
A spoofed email body might contain **direct links/hyperlinks** designed to **lure users** into providing sensitive details
- 4 **Email attachment**
Attackers can **embed malicious javascript, VBScript or .exe files** within the documents and PDF files sent as attachments. You need to examine these attachments within a controlled forensic environment.



Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Step 3: Examining Email Messages

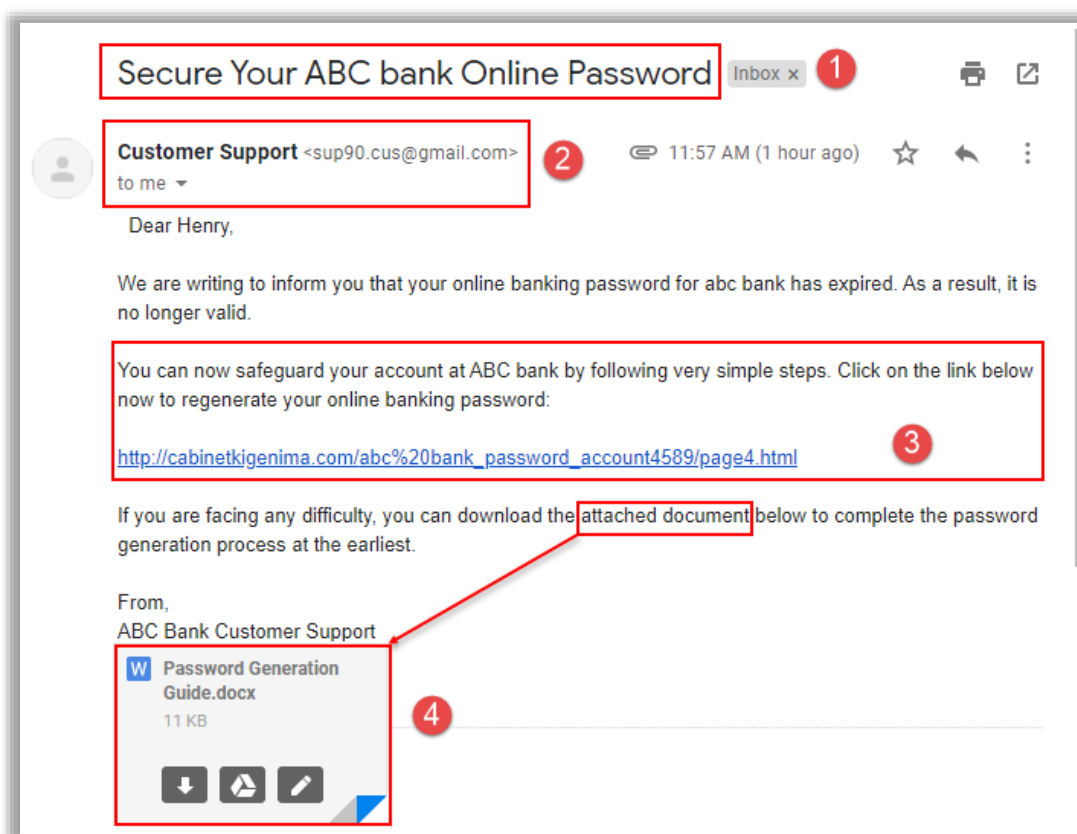


Figure 11.11: Examining email messages

Forensic investigators should closely examine the following areas while inspecting the acquired email messages:

1. Subject

This field of an email informs the recipient about the message that the email intends to convey. Most of the spoofed emails are designed to create a sense of panic/urgency that induces the victim to open the mail and go through its contents.

2. Sender Email Address

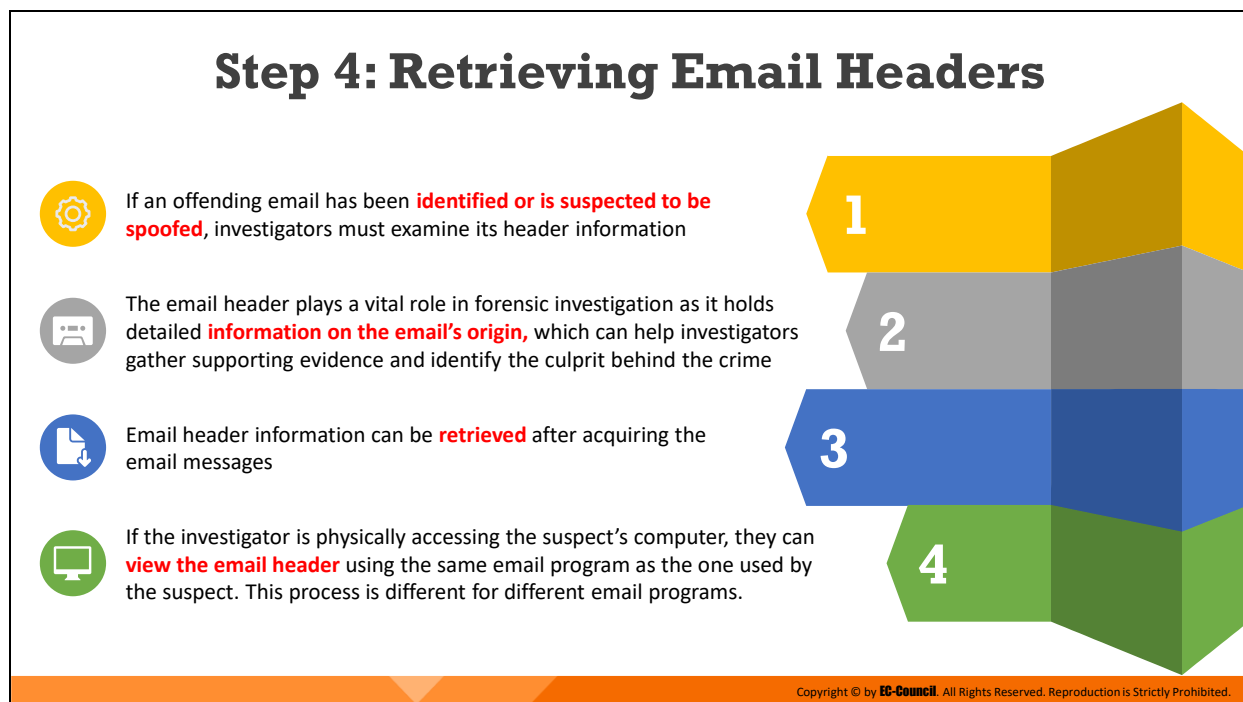
Attackers trick target users by making suspicious emails appear authentic. For example, an email appearing in the name of a bank, but which uses a Gmail account instead of the respective bank's domain, is a strong indicator of spoofing.

3. Email Body

The email body contains the main message of the email. A spoofed email body might include direct links/hyperlinks that lure users to provide sensitive details. The body of a spoofed email often has poorly structured language/sentences that do not appear professional.

4. Email attachment

Attackers usually send documents or pdf copies with extensions such as .exe, .vbs, .js, .wsf, and .zip as attachments in emails. These attachments are designed to execute hidden programs such as spyware and malware on the user's computing system, which can compromise sensitive data.



Step 4: Retrieving Email Headers

Email headers are a vital component of an email that can help investigators trace the origin of an email. These headers provide information on the sender and the recipient of the email. These details on the source and recipient(s) are provided using the headers “From” and “To,” respectively.

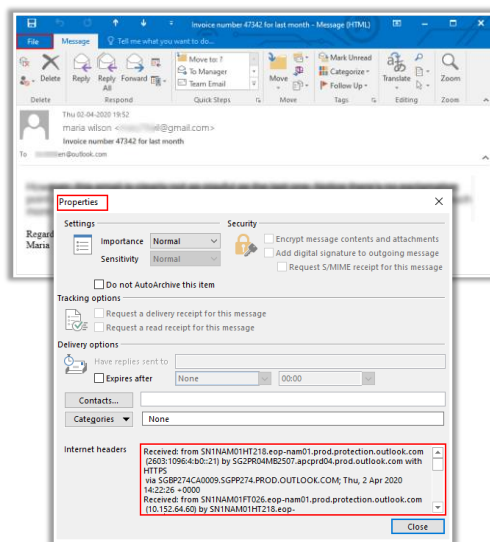
The headers also contain information on the path taken by an email while in transit. Each MTA that receives the email message, as it travels from its source to the destination, changes the email header section. Therefore, investigators should examine the email header section and thus obtain crucial data of evidentiary value and trace the perpetrator.

Investigators can retrieve header information from any email message after its acquisition. In case they have physical access to the suspect's system, they can use the same email program as the one used by the suspect to view the emails. The procedure for retrieving email headers differs in each email program.

Retrieving Email Headers in Microsoft Outlook



- ✓ Launch **Microsoft Outlook** and double-click on the email message
- ✓ Click the **File** button located on the top-left and then the **Properties** icon
- ✓ When the **Properties** window opens, select the message header text from the **Internet headers** box, then copy and paste the text in any text editor and save the file



Copyright © by **EC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Retrieving Email Headers in Microsoft Outlook

Steps below are in reference to Microsoft Outlook 2016 desktop application:

1. Launch Microsoft Outlook desktop application
2. Review all email messages of the suspect's email account and double-click on the email message that you wish to save
3. Click the File button located on the top-left and then the Properties icon.
4. When the Properties window opens, select the message header text from the Internet headers box
5. Copy and paste the text in any text editor and save the file

Thus, you can save the message headers text of all the required email messages to conduct further investigation on them.

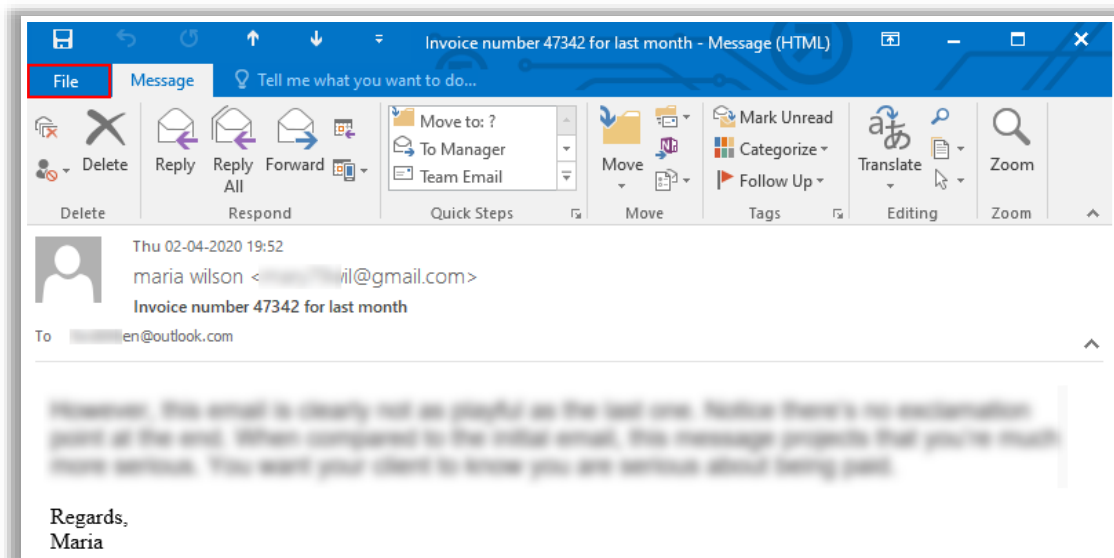


Figure 11.12: The File icon on Microsoft Outlook desktop application

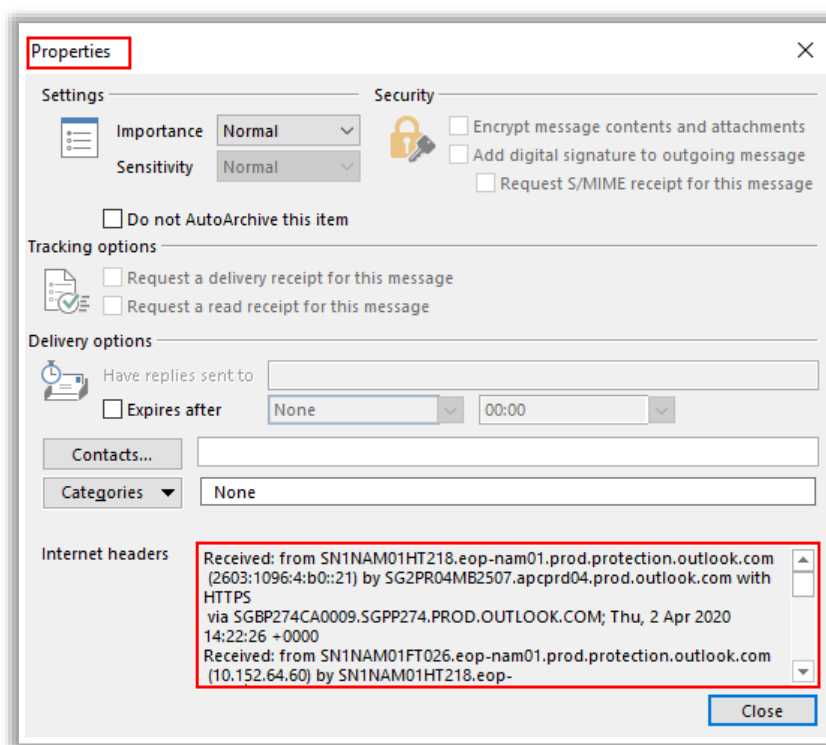
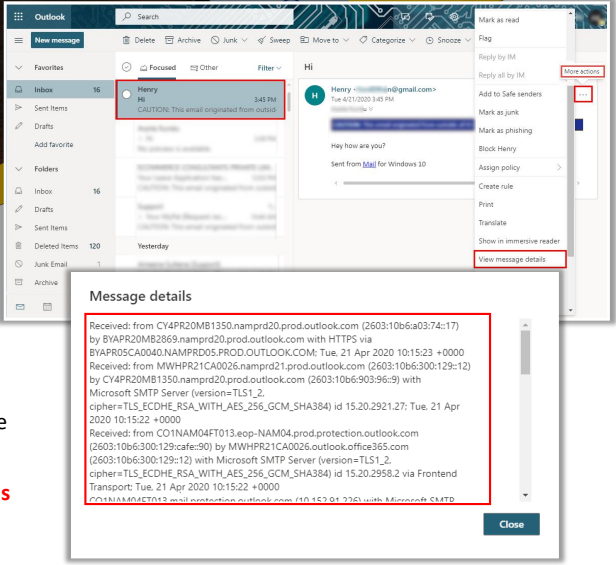


Figure 11.13: Properties tab showing message header text

Retrieving Email Headers in Microsoft Outlook.com

- ❑ Log on to **Microsoft Outlook.com** and select the received mail for which you would like to see headers
- ❑ Click on the **More actions** drop-down button and navigate to the **View message details** option
- ❑ Select the message headers text from the **Message details** box, copy and paste the text in any text editor, and save the file



The screenshot shows the Microsoft Outlook.com web application. On the left is the navigation pane with folders like Favorites, Sent Items, Drafts, and Deleted Items. The main area displays an email from 'Henry' with a subject 'Hi'. A 'More actions' dropdown menu is open, showing options like 'Reply by IM', 'Add to Safe senders', 'Mark as phishing', 'Block Henry', 'Assign policy', 'Create rule', 'Print', 'Translate', 'Show in immersive reader', and 'View message details'. The 'View message details' option is highlighted. Below this, a 'Message details' box is open, showing the raw email headers. The headers text is highlighted with a red box. The headers include information about the email's origin, delivery time, and security details.

Received: from CY4PR20MB1350.namprd20.prod.outlook.com (2603:10b6:a03:74:17) by BY4PR20MB2869.namprd20.prod.outlook.com with HTTPS via BY4PR20MB2869.namprd20.prod.outlook.com Tue, 21 Apr 2020 10:15:23 +0000
Received: from MNWPR21CA0026.namprd21.prod.outlook.com (2603:10b6:300:129:12) by CY4PR20MB1350.namprd20.prod.outlook.com (2603:10b6:903:96:9) with Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.2921.27; Tue, 21 Apr 2020 10:15:22 +0000
Received: from CO1NAM04FT013.eop-NAM04.prod.protection.outlook.com (2603:10b6:300:129:cafe:90) by MNWPR21CA0026.outlook.office365.com (2603:10b6:300:129:12) with Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.2958.2 via Frontend Transport; Tue, 21 Apr 2020 10:15:22 +0000
Content-Type: text/html; charset=utf-8

Copyright © by **EC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Retrieving Email Headers in Microsoft Outlook.com

The steps demonstrated below are in reference to Microsoft Outlook web application:

1. Log on to Microsoft Outlook.com
2. Click on the mail for which you would like to see headers
3. Click on the More actions drop-down button, navigate to the View message details option and click on it
4. Select the message headers text from the Message details box, copy and paste the text in any text editor and save the file

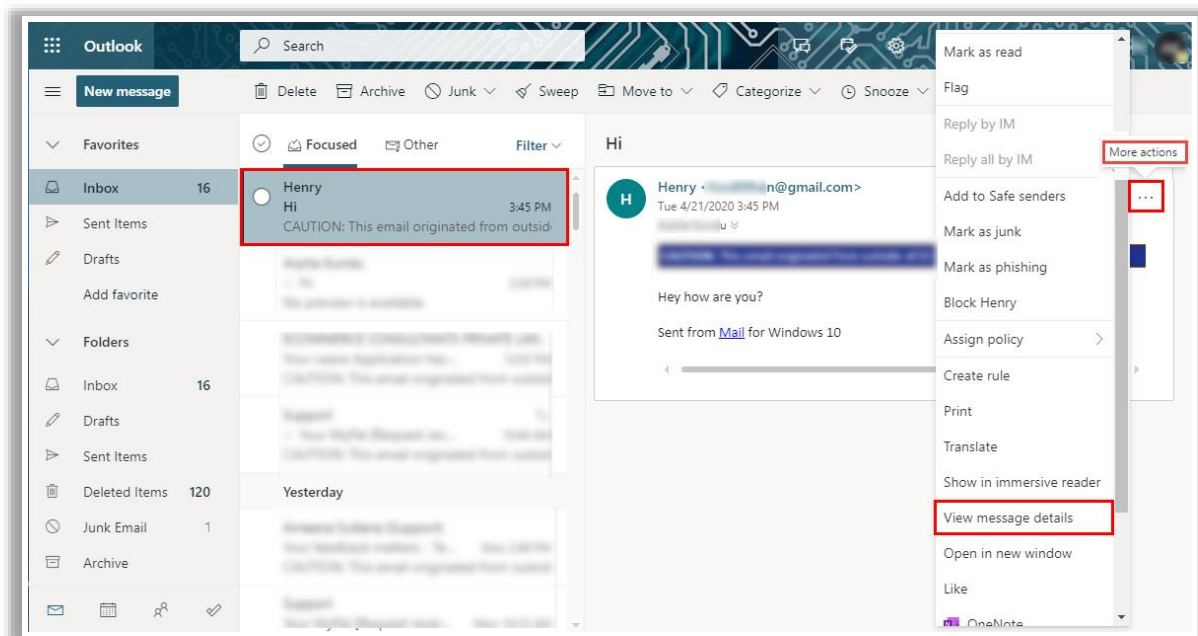


Figure 11.14: Navigating to More Actions → View message details

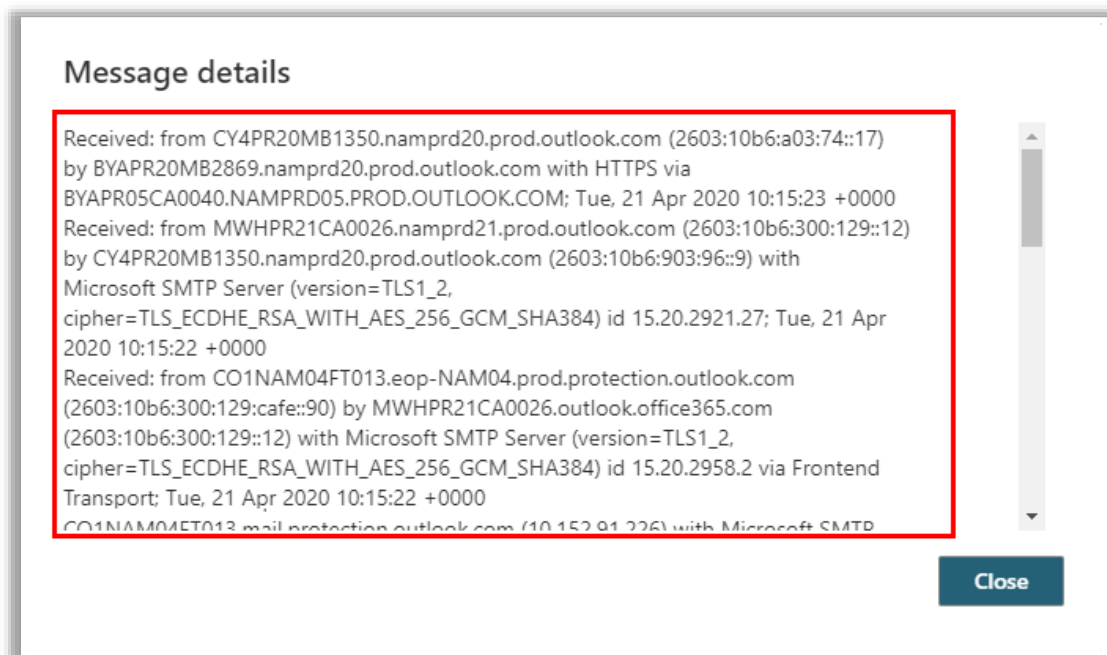


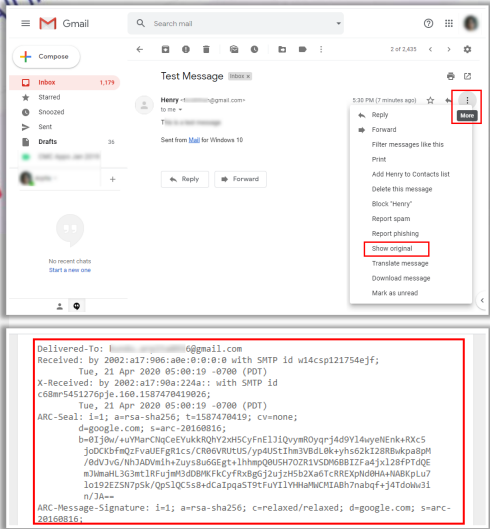
Figure 11.15: Message header text as found in Message details box

Retrieving Email Headers in Gmail

Log on to **Gmail** and select the received mail for which you would like to see headers

Click on the **more** drop-down button and navigate to the **Show original** option

Select the message headers text, copy and paste the text in any **text editor**, and save the file



The screenshot shows the Gmail interface. On the left, the 'Inbox' is visible with 1,176 messages. The main area displays an email from 'Henry' with the subject 'Test Message'. The email body contains a 'Test Message' and a link to 'See original'. The 'More' button (three vertical dots) is highlighted with a red box. Below the email, the 'Show original' option is also highlighted with a red box. The bottom part of the image shows the raw email headers in a text editor, including fields like 'Delivered-To', 'Received', 'X-Received', 'ARC-Message-Signature', and 'ARC-Message-Id'.

```
Delivered-To: [redacted]@gmail.com
Received: by 2002:a17:906:a8e:0:8:0 with SMTP id v14csp121754efj;
  Tue, 21 Apr 2020 05:00:19 -0700 (PDT)
X-Received: by 2002:a17:90a:224a: with SMTP id
  c08m545127apj; 160-1587470419025;
  Tue, 21 Apr 2020 05:00:19 -0700 (PDT)
ARC-Seal: i=1; a=rsa-sha256; t=1587470419; cv=none;
  d=google.com; s=arc-20160816;
  b=01j0w/uuYMarChQcEYakkRQyZxHSCyFnE131QymR0YqrJ4d9Y14uyetEnk+R0c5
  JoCKbfnQzFvaUEfgr1cs/CR00VRLUT5/yp4USC1hm3VBdL0k+yhs62kZ28R0kpa8pP
  /6dVJvG/hh3ADwLh+2uys8u6dgt+1hmpQ0U5H70Z1VSDP6881274jx128PPTdQe
  n3maki3G3et18f+jmtd08WPKCyF8digsJvujH52xatC0RExp0d8HuaVabKpi7
  lo192EZ5N7p5k/Qp51Qc5S8+dCa1pq45T9tFUV1YHMaMCHABh7nabqf+j4tdom31
  n/3A=
ARC-Message-Signature: i=1; a=rsa-sha256; c=relaxed/relaxed; d=google.com; s=arc-
  20160816;
```

Retrieving Email Headers in Gmail

1. Log on to Gmail
2. Select the received mail for which you would like to see headers
3. Click on the More drop-down button and navigate to the Show original option
4. Select the message headers text, copy and paste the text in any text editor, and save the file

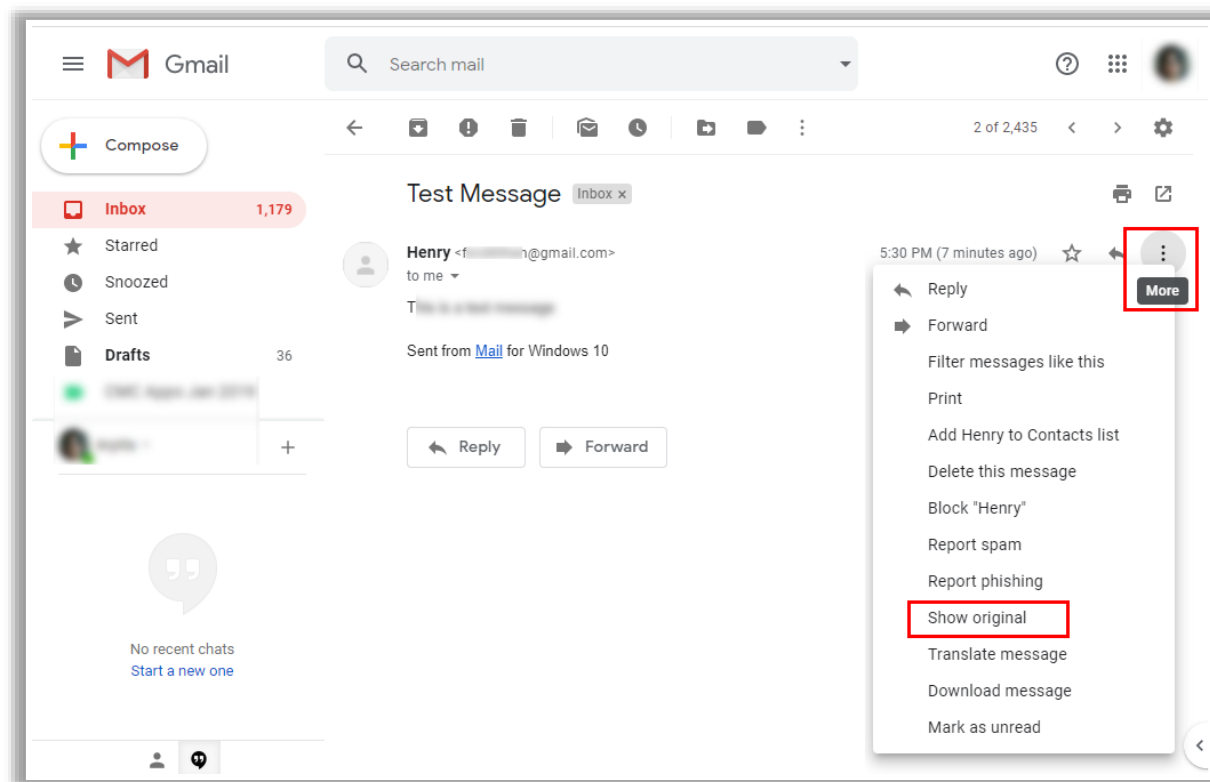


Figure 11.16: Navigating to More → Show original on Gmail



Figure 11.17: Message header text

Step 5: Analyzing Email Headers

- 01 **Timestamp:** Shows the **date and time** when the mail was sent
- 02 **From:** Shows the **email ID of the sender** as it is visible to the recipient; this can be forged in case of spam emails
- 03 **To:** Shows the **email ID of the recipient**
- 04 **Message ID:** As per **RFC 2822**, a specific email message should have a globally unique message identifier
The first part of the message ID before '@' contains the timestamp of the email (1587617857 in Unix epoch format converts to Thursday April 23, 2020 04:57:37 am in UTC)
The part of message ID after '@' contains the Fully Qualified Domain Name (here, the domain name is mail.yahoo.com)
- 05 **Subject:** Shows the subject as given by the **sender**
- 06 **MIME-Version:** Multi-purpose Internet Mail Extensions are used to **support non-text attachments** such as video, images, and audio and the default version is 1.0

```
23 Date: Thu, 23 Apr 2020 04:57:37 +0000 (UTC) 1
24
25 From: George Smith <smithgeorge2323@yahoo.com> 2
26
27 To: "smith34rose@gmail.com" <smith34rose@gmail.com> 3
28
29 Message-ID: <872810067.99762.1587617857879@mail.yahoo.com> 4
30
31 Subject: Choose Safe Transportation everyday 5
32
33 MIME-Version: 1.0 6
34
35 Content-Type: multipart/mixed;
36 boundary="-----_Part_99761_989095541.1587617857879"
37
38 References: <872810067.99762.1587617857879.ref@mail.yahoo.com>
39
40 X-Mailer: WebService/1.1.15756 YMailMorrin Mozilla/5.0 (Windows NT
41 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
42 Chrome/81.0.4044.113 Safari/537.36
43
44 Content-Length: 1645
45
```

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Analyzing Email Headers (Cont'd)

07 Received Header

- The entries in the received headers are of significant forensic value as these **cannot be forged** unlike other email header elements
- The number of received headers found in an email message **depends on the mail servers** that processed the message as it travelled from source to destination
- Investigators should start with the bottommost received header (**B**), as it is closest to the source and then move towards the top headers (**A**)
- Here, the **B header** is showing the domain name from which the email message originated (sonic302-19.consmr.mail.sg3.yahoo.com), the associated IP address (106.10.242.139), and the date and time in PDT

```
1 Delivered-To: smith34rose@gmail.com
2
3 Received: by 2002:a05:6214:204:0:0:0:0 with SMTP id i4cep1473025qvt; 4
4 Wed, 22 Apr 2020 21:57:43 -0700 (PDT) A
5
6 X-Received: by 2002:a63:5f87:: with SMTP id t129mr2118945pgb.299.1587617863151; 7
7 Wed, 22 Apr 2020 21:57:43 -0700 (PDT)
8
9 Received: from sonic302-19.consmr.mail.sg3.yahoo.com (sonic302-19.consmr.mail.sg3.yahoo.com 10
10 [106.10.242.139])
11 by mx.google.com with ESMTPS id 93e1119340plc.369.2020.04.22.21.57.42
12 for <smith34rose@gmail.com>
13 (version="TLS1_3 cipher=ECDHE-RSA-AES128-GCM-SHA256 bits=128/128); 14
14 Wed, 22 Apr 2020 21:57:43 -0700 (PDT) B
15
16
```

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Analyzing Email Headers (Cont'd)

08

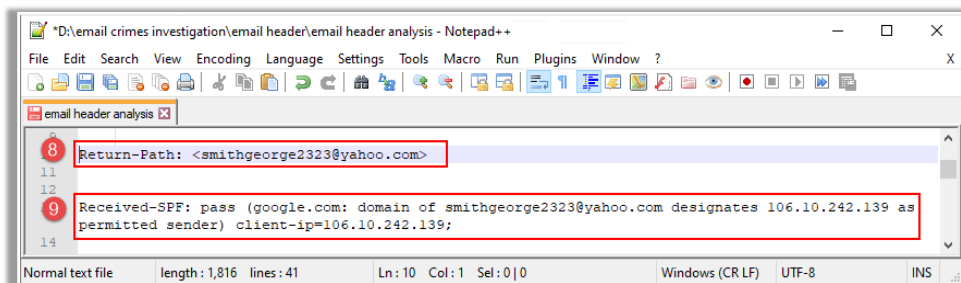
Return-Path

- ✓ It is the **bounce address for emails** that are sent but not delivered to the recipient
- ✓ If the sender's email address and the return-path address are different, it generally **indicates email spoofing**

09

Received-SPF

- ✓ Sender Policy Framework or SPF refers to the process that enables organizations to **mention servers** that can send emails on behalf of their domains
- ✓ An email header showing a failed SPF check can help **detect spam messages**



```
*D:\email crimes investigation\email header\email header analysis - Notepad++
File Edit Search View Encoding Language Settings Tools Macro Run Plugins Window ?
Return-Path: <smithgeorge2323@yahoo.com>
Received-SPF: pass (google.com: domain of smithgeorge2323@yahoo.com designates 106.10.242.139 as permitted sender) client-ip=106.10.242.139;
```

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Analyzing Email Headers (Cont'd)

10

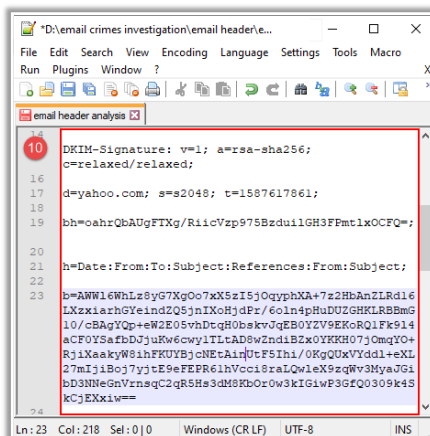
DomainKeys Identified Mail (DKIM) Signature

- ❑ It offers a **cryptographic way** of verifying whether a received email has actually originated from the sending domain



Different elements of the DKIM signature

"v=" field stands for the DKIM signature version which should always be set to 1
"a=" field shows the algorithm (sha256) used to generate the signature
"c=" field denotes the canonicalization algorithm used. It shows if there is any modification in the email in terms of whitespace or line-wrapping; the first value before "/" is for the header and the rest is for the body
"d=" field refers to the domain of the sender
"s=" field refers to the selector to identify the DNS public key
"t=" field denotes the timestamp of the signature in Unix epoch time and should always match or be close to the time reflected in the Received header and Message ID fields
"bh=" field is the hash for the body as per the hashing algorithm in use and then encoded in Base64
"b=" field includes the DKIM signature that should be calculated as per the header field mentioned in the "h=" field



```
*D:\email crimes investigation\email header\...
DKIM-Signature: v=1; a=rsa-sha256;
c=relaxed/relaxed;
d=yahoo.com; s=s2048; t=1587617861;
bh=oahrQbAUGFTXg/R1icVzp975BzduilGH3FPmt1xOCFQ==;
h=Date:From:To:Subject:References:From:Subject;
b=AWW16WhLs8yG7XgOo7xX5zI5jOqyphXA+7z2HbAnZLRd16LXzx1arhGveindZQ5jnIXoHjdPr/6o1nspHuDUZGHKLBBmG10/cBAgYQp+eW2E05vhtqH0bskvJqEB0YV9KEK0RQ1Fk914aCF0YSafBd3juRw6cwy1LTAD8wZndiBZx0YKXh07jOmQYO+RjiKaakyW8lhFKUYBjcNEtA1qUtFSIh1/0KqQUxVYddl+eXL27mIj1Boj7yjtE9eFEPR6lhVcci8raLQwleX9zqWv3MyaJG1bD3NNeGnVrnsqC2qR5Hs3dM8RbOr0w3kIG1wF3GfQ0309k4GkCjEXx1w==
```

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Step 5: Analyzing Email Headers

Analyzing email headers is a crucial aspect of email crime investigations, as they store email metadata and other information. The following details are contained in the email headers:

1. Timestamp

This reflects the date and time when an email was sent

2. From

This header displays the email ID of the sender as seen at the recipient's end. The "From" header can be forged in the case of spam emails.

3. To

This header displays the recipient's email ID

4. Message ID

Each email message has a unique ID associated with it. No two emails, even in the same email chain, can have the same Message ID. These Message IDs are generated by the globally unique MTA/mail server of the sending mail system. The globally unique Message ID of an email message is an indicator of its authenticity. The part before the "@" in a Message ID denotes the timestamp associated with that particular email message. The part of the Message ID after "@" denotes the fully qualified domain name (FQDN), which shows the complete domain name of a host/server on the Internet.

5. Subject

This header displays the subject as provided by the sender

6. MIME

Multi-Purpose Internet Mail Extension (MIME) allows email users to send media files such as audio, video, and images as a part of the email message

Examples of MIME Headers

- **MIME-Version:** This header shows that the message is MIME formatted. By default, this header is set to a value of 1.0.
- **Content-Type:** This header specifies the content type and sub-type in a message such as the following:
 - **Text/plain** shows the type of message
 - **Audio/mp3, image/jpeg, video/mp4**, respectively, represent email messages containing audio files, image files, and video files
 - **Multipart/signature** shows that an email message has a signature
 - **Multipart/mixed** indicates that an email has text along with attachments
- **Content Disposition:** This header specifies how a message, or its body part, must be presented
- **Content-Transfer Encoding:** This header represents the encoding contained in the message
- **Content Description:** This is an optional MIME header used to provide additional information pertaining to the content of an email message

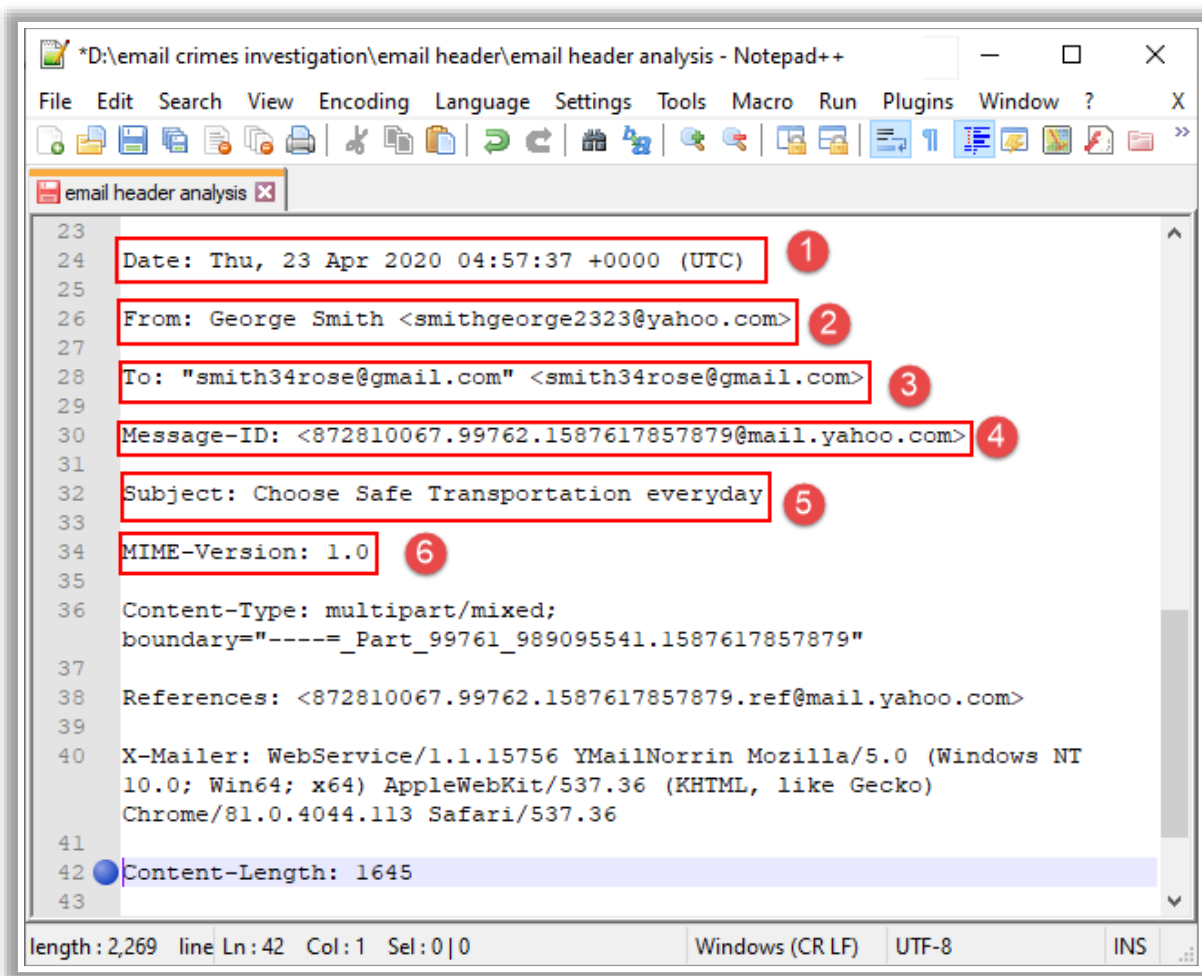


Figure 11.18: Analyzing email headers

7. Received Header

The received header contains details of all the mail servers through which an email message travels while in transit. These headers are generated every time an email transmits through a mail server/MTA on its route to the recipient.

Whenever any SMTP server receives an email message, a received header is added to the email. In the email header, received headers are placed in reverse order, that the most recent or the last generated received header appears first (at the top marked by A in the figure below) and the received header that was generated first appears last (at the bottom marked by B in the figure below).

Therefore, investigators need to start examining the bottommost received header, as it reflects information about the sender's mail server. Then, they can proceed toward the top, which will provide them data about the mail server and IP address associated with the recipient.

In the figure below, the B header is showing the domain name from which the email message originated (sonic302-19.consmr.mail.sg3.yahoo.com), the associated IP address (106.10.242.139), and the date and time in PDT.

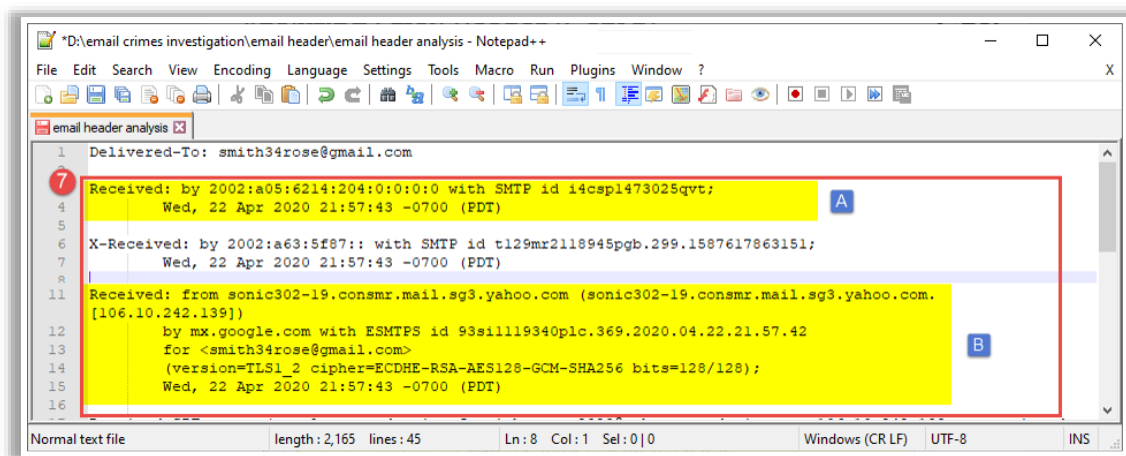


Figure 11.19: Analyzing received headers

8. Return-Path

This header is used to specify the email address to which an email message will be sent/returned if it fails to reach the intended recipient. When an email fails to reach the intended recipient, it bounces. That is, it is returned to the sender of the email, unless the sender specifies a different email address where bounced emails should be sent. If the return path address and the sender's email address differ, it is an indicator of spamming/spoofing.

9. Received-SPF

The Sender Policy Framework (SPF) prevents sender address forgery. SPF allows organizations to designate servers that can send emails on behalf of their domains. The framework implements an SPF record, which refers to a DNS record added to the DNS zone of an organization's domain. Within the SPF record, an organization can define the host names and/or IP addresses that are authorized to send emails from their domain. Through the implementation of SPF, the results for email exchanges can be as follows.

- **Received-SPF: None:** This means that no SPF record was found for the domain.
- **Received-SPF: Neutral:** This means that the sender's IP address is neither authorized nor restricted from sending emails on behalf of the organization's domain. A neutral result is treated in the same manner as a "None" result.
- **Received-SPF: Pass:** This means that the sender's IP address is authorized to send emails from the domain.
- **Received-SPF - fail, or hard fail:** This means that the email was rejected by the recipient's mail exchanger because the sender's IP address is not authorized to send emails from the domain. The SPF hard fail is executed by adding an "-all" mechanism to an SPF record.

Example: `v=spf1 ip4 : 207.84.200.37 -all`

In the above example, “-all” means that the senders that are not listed in the mentioned DNS record (i.e., 207.84.200.37) should be treated as unauthorized and emails from them should be rejected. Only the IP address 207.84.200.37 is authorized to send emails.

- **Received-SPF: Softfail:** This means that there is possibility that IP addresses might or might not have the authorization to send emails on behalf of the domain mentioned.

Example: `v=spf1 include:modprod.outlook.com ~all`

In the example above, the “~” symbol indicates that mails coming through any server not mentioned here will be delivered but treated as a softfail. In this case, the mailbox provider marks the message as spam or junk email. Only mails coming from Microsoft Office 365 will be tagged as SPF PASS.

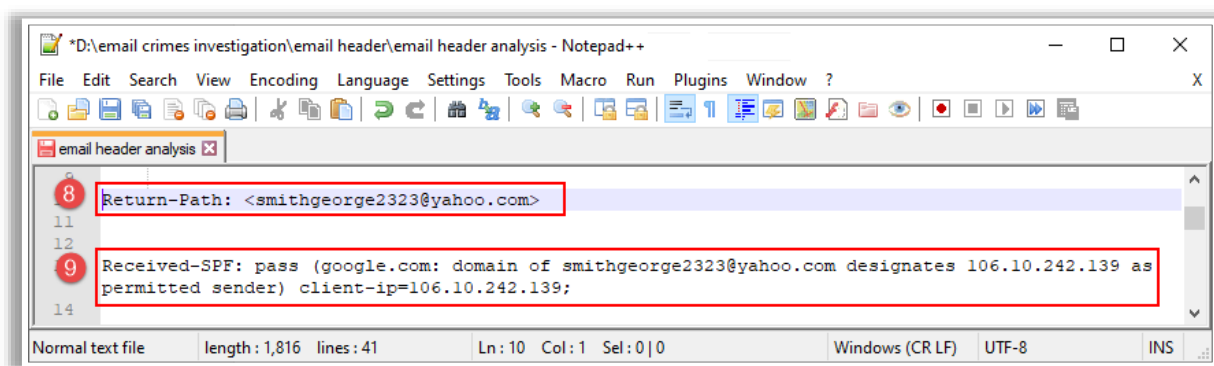


Figure 11.20: Analyzing Return-Path and Received-SPF fields

10. DomainKeys Identified Mail Signature:

DomainKeys Identified Mail (DKIM) refers to an email authentication method that helps safeguard the senders and recipients of emails from phishing, spoofing, and spamming. The technique verifies that the email message received by the receiver has been sent from a legitimate mail server. This method of email authentication uses public key cryptography to detect and prevent the delivery of malicious emails. This digital/DKIM signature is secured through encryption. DKIM also ensures that emails and their contents are not altered while in transit between the sender's and the recipient's servers. Most email service providers look for DKIM signatures in emails.

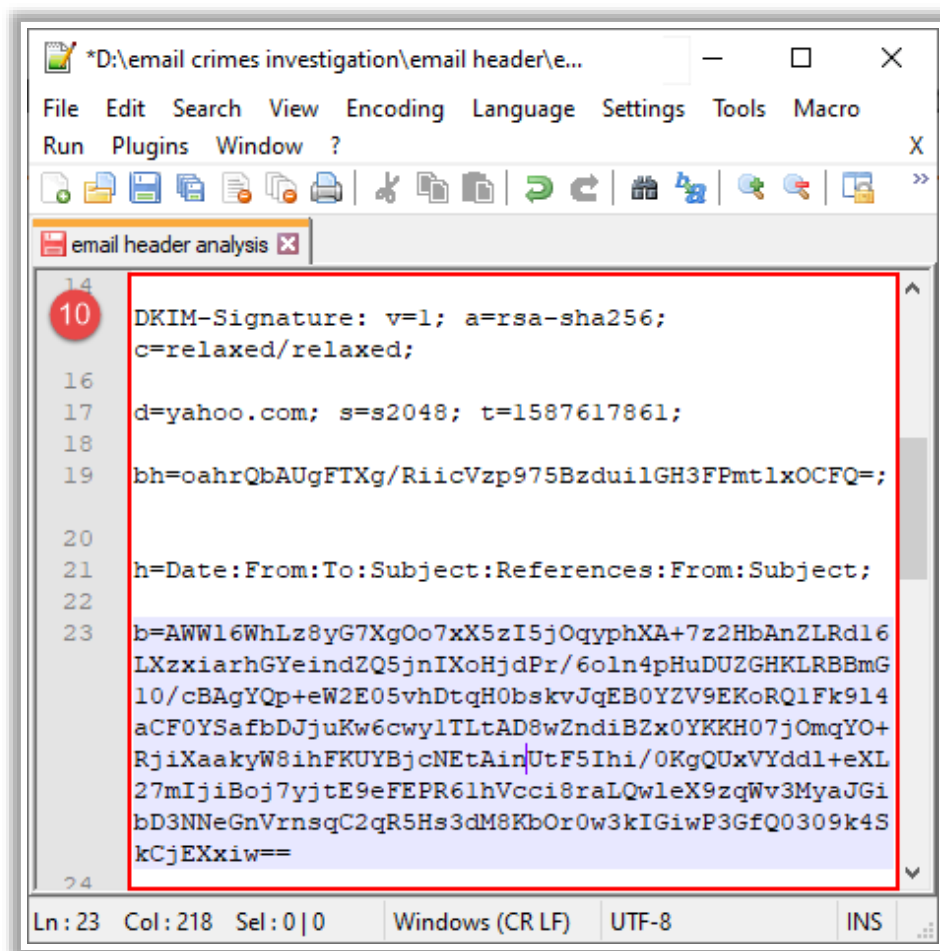
The mail server receiving the email can validate the sender's DKIM signature with the help of the public cryptographic key registered in the DNS. The inbound server uses this public key to decrypt the signature (a hash value) and verify it with a newly computed hash value. If the two-hash values match, then the message is regarded as authentic and unaltered.

Example of a DKIM Signature Header

*DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed;
d=gmail.com; s=20161025pm;
h=mime-version:from:date:message-id:subject:to;
bh=RqIJ8naev02DhEPJtIFAsdUqiGR7RyzmJ9cSxw5KzCY=;
b=BYQQZk7S77sJJef1WEXGyTmfb8sUF6S7W8wi93lhh7WthcGjc2Ik/NfpgqVpeXrhHP
Ujuv36G1DVe6TBzdHsjdDLzs4b3sATMSAZNZAEdA44Tm5ooGJbhBQ8iNjRgD7eYWeEPL
cFOU/eBBU1Nteh9MOqxIBJYJ1ZHGB+dz9zyfsyQAIHik3Db1GLhXCvfYdkEWydjGN2CH
7/IdO3IjccF5z5sVwPYDz69dCKmyl3IWckXU/KU+xRVX4NjffZoWHBoxOK47H7YcJZye
aFoeirs/UJVZH2xKZcjSMhBS9Q/4GAuACp5ehT2GtM7BoQB/H4wVV7gdQrrHjBUewJGX
IDIQ=*

Analysis of different parts of the DKIM signature header is given below:

- **DKIM-Signature:** This shows the header for DKIM signed messages.
- **v=1:** It shows the DKIM version used by the sending server, whose value is 1
- **a=rsa-sha256:** The “a=” field indicates the hash algorithm used for the generation of the private or public key. rsa-sha1 and rsa-sha256 are the two officially supported signature algorithms for generating hash values for the private/public key
- **c=relaxed/relaxed:** The field “c=” indicates the canonicalization algorithm used. It shows if there is any modification in the email in terms of whitespace or line-wrapping. The first value before “/” is for the header and the rest is for the body.
- **d=gmail.com:** The field “d=” represents the sender’s email domain
- **s=20161025pm:** The field “s=” refers to the selector to identify the public DKIM key
- **bh=RqIJ8naev02DhEPJtIFAsdUqiGR7RyzmJ9cSxw5KzCY=:** This represents the hash value for the body according to the hashing algorithm in use and then encoded in Base64
- **b=:** This holds the DKIM signature that should be calculated according to the header field provided in the “h=” field



```
*D:\email crimes investigation\email header\e...
File Edit Search View Encoding Language Settings Tools Macro
Run Plugins Window ?
email header analysis x
14 DKIM-Signature: v=1; a=rsa-sha256;
15 c=relaxed/relaxed;
16
17 d=yahoo.com; s=s2048; t=1587617861;
18
19 bh=oahrQbAUgFTXg/RiicVzp975BzduilGH3FPmtlxOCFQ=;
20
21 h=Date:From:To:Subject:References:From:Subject;
22
23 b=AWWl6WhLz8yG7XgOo7xX5zI5jOqyphXA+7z2HbAnZLRdl6
  LXzxiarhGYeindZQ5jnIXoHjdPr/6oln4pHuDUZGHKLRBBmG
  10/cBAgYQp+eW2E05vhDtqH0bskvJqEB0YZV9EKoRQ1Fk914
  aCF0YSafbDJjuKw6cwy1TLtAD8wZndiBZx0YKKH07jOmQYO+
  RjiXaakyW8ihFKUYBjcNEtAinUtF5Ihi/0KgQUxVYddl+eXL
  27mIjiBoj7yjtE9eFEPR6lhVcci8raLQwleX9zqWv3MyaJGi
  bD3NNeGnVrnsqC2qR5Hs3dM8KbOr0w3kIGiwP3GfQ0309k4S
  kCjEXxiw==
24
Ln: 23 Col: 218 Sel: 0 | 0 Windows (CR LF) UTF-8 INS
```

Figure 11.21: Analyzing DKIM signature

Analyzing Email Headers: Checking Email Authenticity

- ❑ Once the sender's email address has been identified, investigators should check **whether it is valid**
- ❑ Use Email Dossier, a **scanning tool** included in the CentralOps.net suite of online network utilities
- ❑ This tool provides **information** about e-mail address, including the mail exchange records
- ❑ It **initiates SMTP sessions** to check address acceptance, but it never actually sends e-mail

Other tools to check email validity:

- Email Address Verifier
<https://tools.verifyemailaddress.io>
- Email Checker
<https://email-checker.net>
- G-Lock Software Email Verifier
<https://www.glocksoft.com>

The screenshot shows the 'Email Dossier' web application. At the top, it says 'Investigate email addresses'. Below that is a search bar with '3@gmail.com' entered and a 'GO' button. The interface shows user information: 'user: anonymous [183.82.41.51]', 'balance: 49 units', and links for 'log in' and 'account info'. A status bar at the top right says 'CentralOps.net'. The main section is titled 'Validating 3@gmail.com...'. Below this, 'Validation results' show a 'confidence rating: 3 - SMTP' and a message: 'The email address passed this level of validation without an error. However, it is not guaranteed to be a good address. more info'. The 'canonical address' is '<3@gmail.com>'. The 'MX records' section shows a table with columns 'preference', 'exchange', and 'IP address (if included)'. The table lists four records for gmail-smtp-in.l.google.com with IP addresses [108.177.9.27], [64.233.185.26], [173.194.205.27], and [74.125.141.26]. The 'SMTP session' section shows a log: '[Contacting gmail-smtp-in.l.google.com [108.177.9.27]...]' and '[Connected]'. The URL 'https://centralops.net' is at the bottom right.

preference	exchange	IP address (if included)
5	gmail-smtp-in.l.google.com	[108.177.9.27]
10	alt1.gmail-smtp-in.l.google.com	[64.233.185.26]
20	alt2.gmail-smtp-in.l.google.com	[173.194.205.27]
30	alt3.gmail-smtp-in.l.google.com	[74.125.141.26]
40	alt4.gmail-smtp-in.l.google.com	[64.233.186.26]

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Analyzing Email Headers: Checking Email Authenticity

A valid email address is the one to which emails can be sent successfully. It can authenticate the identity of a person or an entity/organization. If forensic investigators come across a suspicious email address during email header investigation, they should use online tools like “Email Dossier” to verify the authenticity of the email address.

▪ Email Dossier

Source: <https://centralops.net>

This tool provides a field to input an email address so that its legitimacy can be verified. The tool provides information about email addresses, which includes mail exchange records. Email Dossier initiates SMTP sessions to check the acceptance of an email address, but it does not actually send an email. When an email address is valid/authentic, the tool provides the result “3 – SMTP” against the field “confidence rating.”

The screenshot shows the 'Email Dossier' website interface. At the top, there's a blue header with the title 'Email Dossier' and the subtitle 'Investigate email addresses'. Below this is a search bar with the text 'email address' and a placeholder for an email address, followed by a 'go' button. The user information is displayed as 'user: anonymous [183.82.41.51]' and 'balance: 49 units', with links for 'log in' and 'account info'. The 'Central Ops.net' logo is visible on the right. The main content area shows 'Validating [redacted]!3@gmail.com...'. Below this, the 'Validation results' section indicates a 'confidence rating: 3 - SMTP' and provides a detailed explanation: 'The email address passed this level of validation without an error. However, it is not guaranteed to be a good address. more info'. The 'canonical address' is shown as '<[redacted]!3@gmail.com>'. The 'MX records' section contains a table with columns for 'preference', 'exchange', and 'IP address (if included)'. The table lists five records for gmail-smtp-in.l.google.com. Finally, the 'SMTP session' section shows a log of the connection process: '[Contacting gmail-smtp-in.l.google.com [108.177.9.27]...]' and '[Connected]'.

preference	exchange	IP address (if included)
5	gmail-smtp-in.l.google.com	[108.177.9.27]
10	alt1.gmail-smtp-in.l.google.com	[64.233.185.26]
20	alt2.gmail-smtp-in.l.google.com	[173.194.205.27]
30	alt3.gmail-smtp-in.l.google.com	[74.125.141.26]
40	alt4.gmail-smtp-in.l.google.com	[64.233.186.26]

Figure 11.22: Validation results on Email Dossier webpage

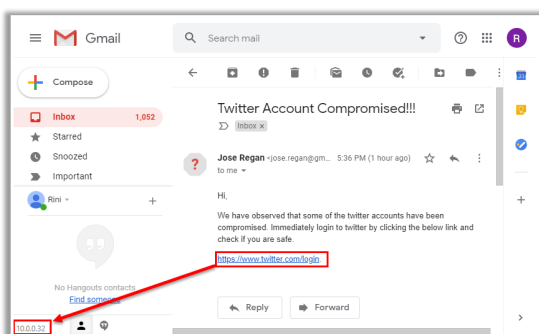
Some other tools to check the authenticity of email addresses are as follows:

- Email Address Verifier (<https://tools.verifyemailaddress.io>)
- Email Checker (<https://email-checker.net>)
- G-Lock Software Email Verifier (<https://www.glocksoft.com>)

Investigating a Suspicious Email

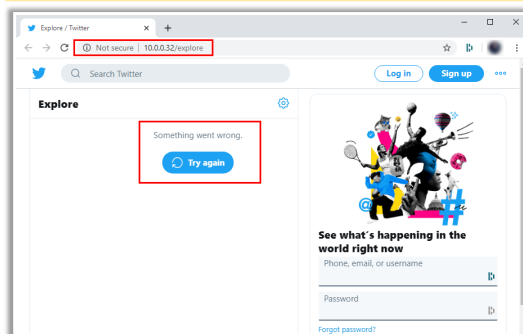
01 Examining the Email Message

- This message invokes a **sense of urgency** asking the recipient to login to their Twitter account
- Inspect the message body thoroughly to look for any suspicious link/attachment
- The screenshot below shows a link to the Twitter login page, which is linked to the private IP address **10.0.0.32**



02 Checking the Link

- Run the link given on the email message on a forensic workstation within a controlled environment
- Here, you can see that the link redirects to a page **10.0.0.32/explore** instead of Twitter's login page URL, which indicates email scamming

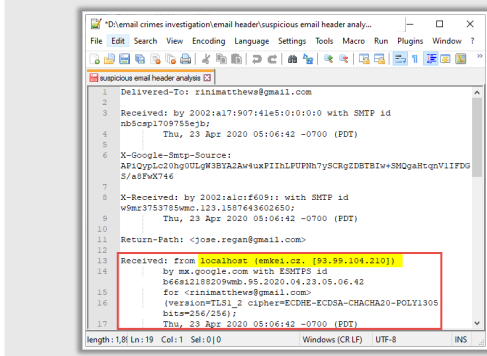


Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Investigating a Suspicious Email (Cont'd)

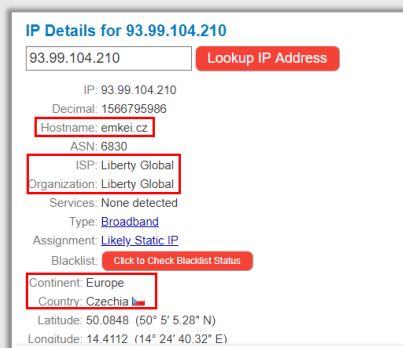
03 Analyze the Received Header Entries

- Start from the bottommost received header entry and then proceed to the top to locate the email ID and IP address of the attacker
- Here, the highlighted received header entry shows the message originated from a website called emkei.cz with the IP address **93.99.104.210**, which strongly indicates email spoofing



04 Examine the Originating IP Address

- Look for IP address details collected from the received header in the **whatismyipaddress website**
- You can see that the IP address is registered under the hostname emkei.cz for an organization called Liberty Global, located in Czechia, Europe



Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Investigating a Suspicious Email (Cont'd)

05 Examine the Received-SPF Field

- ✓ Analyze the Received-SPF header to see if there is any **SPF validation failure**
- ✓ You can see that the received-SPF field below is showing a softfail which indicates that the domain of jose.regan@gmail.com or the sender does not permit the **server IP 93.99.104.210** to send mails on its behalf
- ✓ This **validation failure** is a sign that the message might have been spoofed

```

19 Received-SPF: softfail (google.com: domain of transitioning jose.regan@gmail.com does not
20 designate 93.99.104.210 as permitted sender) client-ip=93.99.104.210;
21 Authentication-Results: mx.google.com;
22 spf=softfail (google.com: domain of transitioning jose.regan@gmail.com does not
23 designate 93.99.104.210 as permitted sender) smtp.mailfrom=jose.regan@gmail.com;
24 dmarc=fail (p=NONE sp=QUARANTINE dis=NONE) header.from=gmail.com
  
```

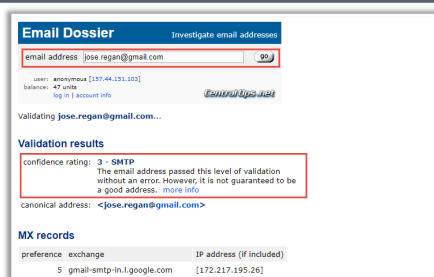
Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Investigating a Suspicious Email (Cont'd)

06

Check the Sender's Email Validity

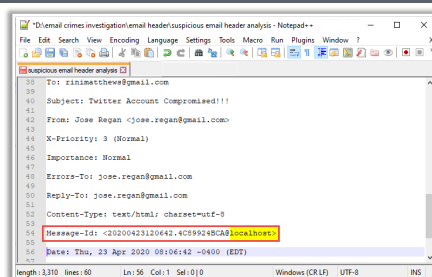
- ✓ Use the Email Dossier website to see whether the sender's email address as shown in the email message is legitimate
- ✓ You can see that Email Dossier shows the email address to be valid
- ✓ This indicates that the attacker might have **compromised the email account** of the user named Jose Regan, or obtained the email address via social engineering techniques



07

Examine the Message ID

- ✓ You can see here that the highlighted part of the message ID shows the **Fully Qualified Domain Name (FQDN)** to be the local host instead of mail.gmail.com which clearly indicates that this is a **spoofed email message**



Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Investigating a Suspicious Email

If an email has been identified as suspicious, its key parts, including the subject field, the body of the email, email headers such as the received headers, the Received-SPF, and the Message ID, must be examined thoroughly to investigate and determine if the email is malicious or spoofed/forged.

Below are presented some of the components that investigators must examine to understand whether an email message is genuine or forged:

1. Examining the Email Message

While examining a suspicious email message, investigators must closely follow the email's subject, body content, and attachment to extract data of evidentiary value. The screenshot below shows an email message whose subject line is written in a manner that would create a sense of urgency in the recipient and, thus, manipulate the reader into clicking on the mail to read the message.

Additionally, the email body contains a link to Twitter's login page. However, hovering the mouse pointer over the given link reveals an IP address (10.0.0.32) at the bottom left of the email's window that looks suspicious because it looks like a private IP address.

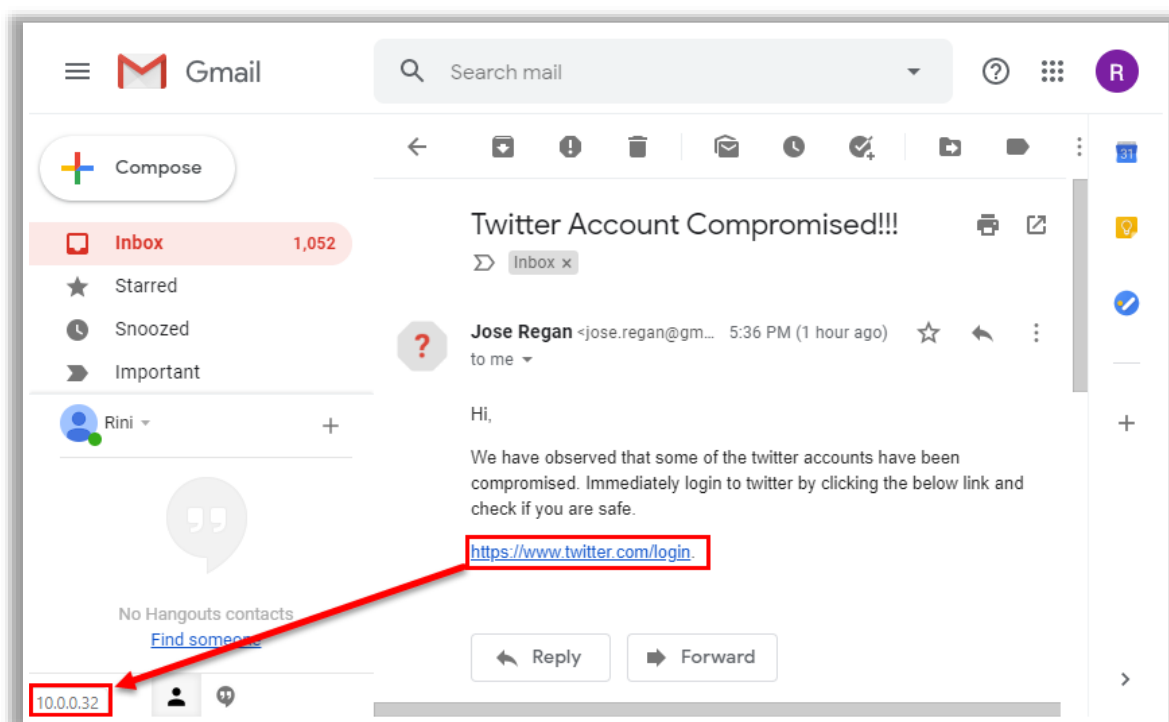


Figure 11.23: Examining a suspicious email message

2. Checking the Link

If any suspicious link has been found on the email body, the investigator can examine the link by opening it in a controlled forensic environment. The screenshot below shows that the link, once clicked on, redirects to a webpage where the browser shows “10.0.0.32/explore” in the URL space instead of the URL for Twitter’s login page.

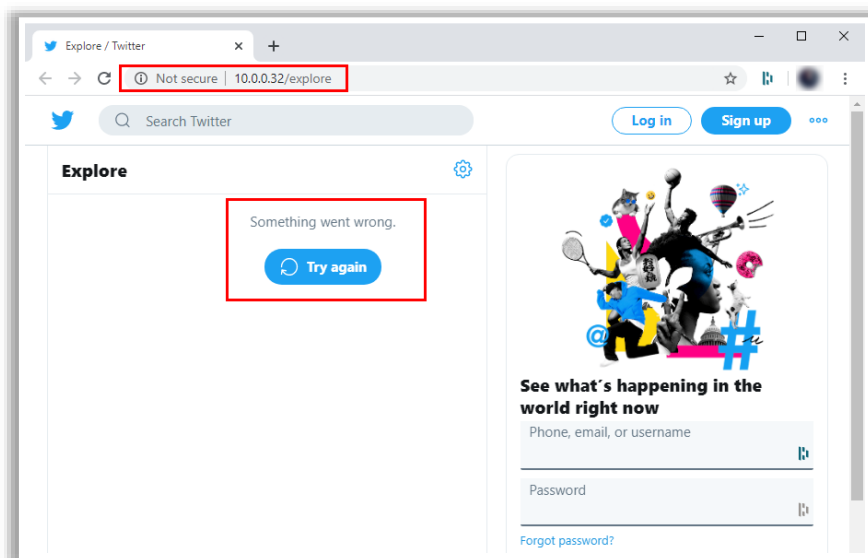


Figure 11.24: The Twitter page opening with suspicious URL

The page opened, however, does contain fields for Twitter usernames and passwords. If the target user mistakenly provides their credentials, the attacker will get an imprint on their attacking machine.

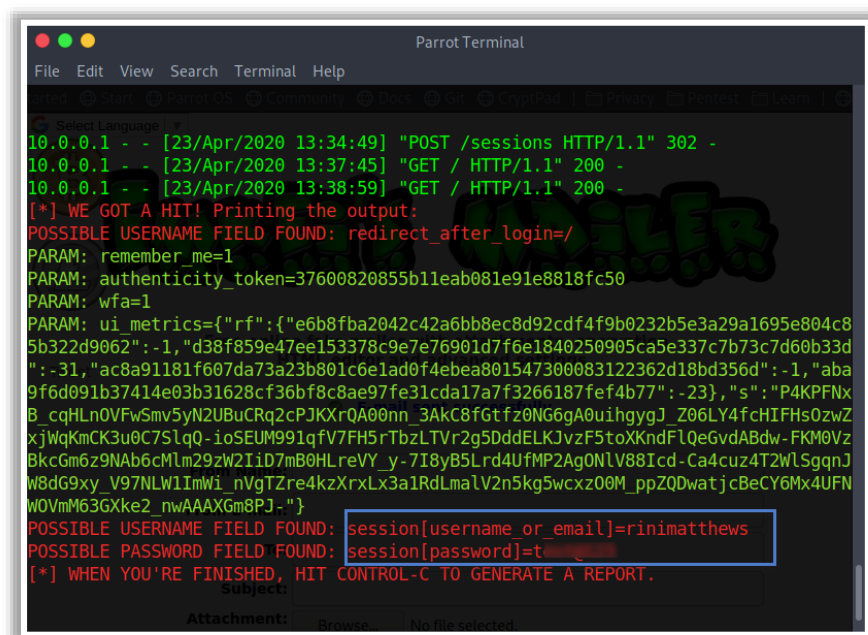


Figure 11.25: Username and password reflecting on attacker’s machine

3. Analyzing the Received Header Entries

To find information on the mail server, IP address, and the hostname used by the attacker/sender, the investigator needs to examine the received header entries in the email header. Details on the hostname, mail server, and IP address used by the attacker are revealed in the bottommost received header.

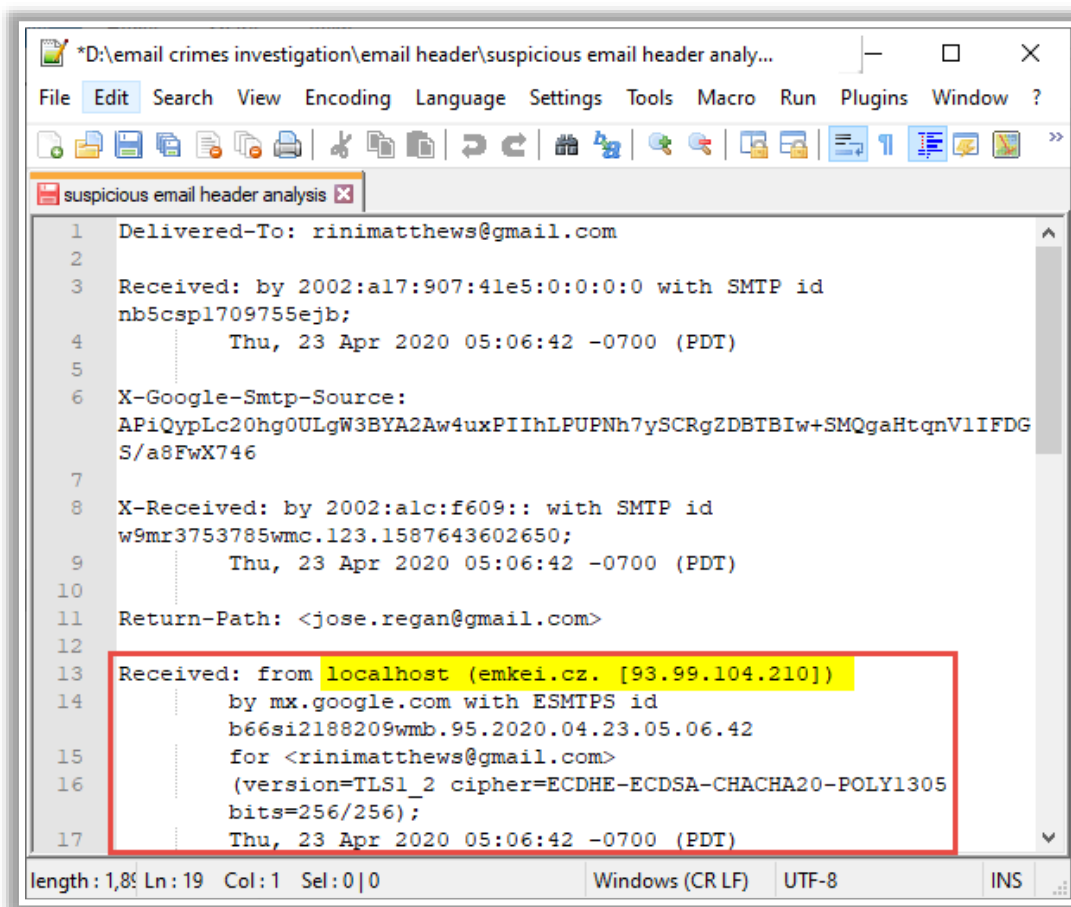


Figure 11.26: Examining received headers in the suspicious message

The screenshot above reflects the content of the bottommost received header, which reveals that the email message originated from a website named emkei.cz with an IP address of 93.99.104.210. The website name and the IP address shown should raise suspicion, as these findings are strong indicators of email spoofing.

4. Examining the Originating IP Address

Investigators can further study the IP address obtained from the received header entry on the website whatismyipaddress.com. The screenshot below reconfirms that the IP address belongs to the hostname emkei.cz. It is associated with an organization named Liberty Global, which is located in Czechia, Europe. These findings further point to email spoofing.

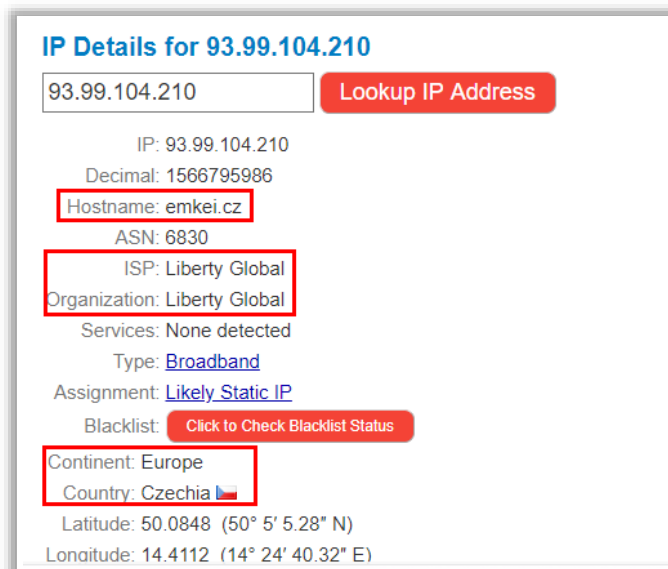


Figure 11.27: IP details for 93.99.104.210 on whatismyipaddress.com

5. Examining the Received-SPF Field

Investigators should also examine the Received-SPF header field to check for any SPF authentication failure.

The screenshot below shows that the Received-SPF field is displaying a “softfail” result, which means that the domain of jose.regan@gmail.com (email ID of the sender as shown in the email) has not authorized the IP address 93.99.104.210 to send emails on its behalf. This failure of authentication is another indicator of an email message being spoofed.

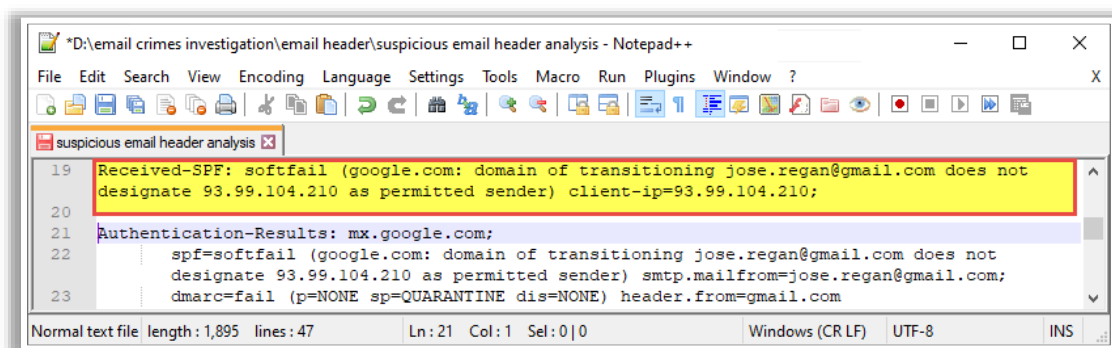


Figure 11.28: Received-SPF showing softfail

6. Checking the Sender’s Email Validity

Once the sender’s email ID is obtained, the investigator should use Email Dossier to verify whether the email address of the sender as shown in the message is authentic.

The screenshot below is taken from Email Dossier, which shows the email address to be valid. With this finding, the investigator can determine that the email account of the user named Jose Regan might have been compromised by the attacker, or the ID has been obtained via social engineering techniques.

Figure 11.29: Email ID validation results on Email Dossier

7. Examining the Message ID

Examining the Message ID is also an important part of the investigation, as it helps determine the authenticity of the email message.

The screenshot below highlighting the Message ID shows that the fully qualified domain name (FQDN) reflects as “localhost” instead of mail.gmail.com (which is the FQDN for Gmail). This finding substantiates the possibility of an email message having been spoofed/forged.

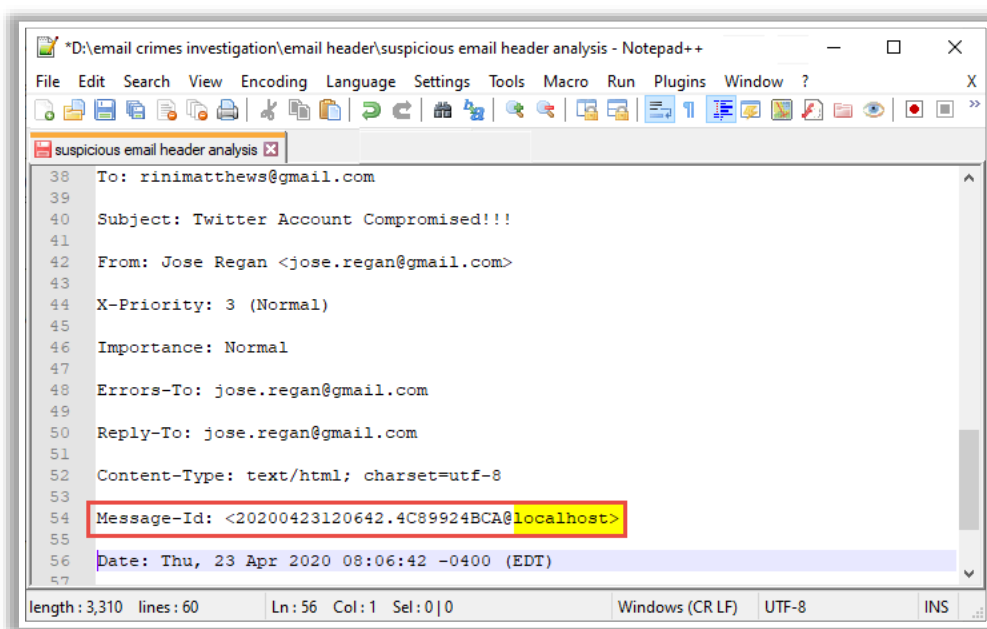


Figure 11.30: Examining Message ID

Step 6: Recovering Deleted Email Messages

 Recovery of deleted e-mail messages **depends upon the e-mail client** used to send the email



Thunderbird

- Messages deleted from the mailbox reside in the **trash folder**, until the trash folder is cleared
- Some forensic tools **might recover** these deleted messages, depending on how soon the recovery is attempted
- Email messages deleted from the Trash section of Local Folders can be completely recovered



Outlook PST

- When email messages are deleted on Outlook, they are moved to the **'Deleted Items'** folder
- If the emails are deleted from the **Deleted Items** folder, they will go to the **unallocated space** of the drive
- The deleted email messages can be **recovered** if that unallocated space is **not replaced** with new data



Use Paraben's Electronic Evidence Examiner tool to retrieve and collect **deleted email messages** from Outlook and Thunderbird Email clients

Copyright © by **EC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Step 6: Recovering Deleted Email Messages

The process of recovering a deleted email message differs based on the email client used to send the email:

Recovering Deleted Email Messages from Outlook PST

In Outlook, email messages, once deleted, are moved to the “Deleted Items” folder. The deleted emails are stored in the “Deleted Items” folder for 14 days (a default retention period that can be modified), after which the messages are automatically deleted from that folder. In the event that these deleted emails are also removed from this folder, they become invisible to the user. However, they are not entirely deleted but moved to the unallocated space of the drive. The deleted email messages can be recovered if that unallocated space is not replaced with new data. These emails can be recovered with forensic tools such as Paraben’s Electronic Evidence Examiner (E3), if it has not been already overwritten.

Recovering Deleted Email from Thunderbird

Thunderbird stores the email messages deleted by the user in the “Trash” folder. The “Trash” folder stores the deleted email messages until they are cleared. Forensic tools such as Paraben’s Electronic Evidence Examiner (E3) can recover those deleted email messages depending on how soon the recovery is attempted. If any email message stored in the Local Trash folder of Thunderbird is deleted, its complete recovery is possible.

Forensic investigators can recover permanently deleted email data from Outlook .pst files and Thunderbird using tools such as Paraben’s Electronic Evidence Examiner. Here, permanently deleted email data refer to deleted email messages that have been deleted or are lost from the

“Deleted Items” folder in the context of Outlook and to those that have been deleted or are lost from the “Trash” folder as well as the “Local Trash” folder of Thunderbird.

- **Paraben's Electronic Evidence Examiner**

Source: <https://paraben.com>

E3 is a comprehensive digital forensic analysis tool designed to handle data more efficiently while adhering to Paraben's P2 Paradigm of specialized focus of the entire forensic exam process. The E3 Platform uses Paraben's advanced plug-in architecture to create specialized engines that examine elements such as email, network email, chat logs, mobile data, file systems, and Internet file analysis—all the while increasing the amount of data that can be processed and utilizing resources through multi-threading and task scheduling. Not only is Electronic Evidence Examiner affordable, it also runs effectively with lower hardware requirements.

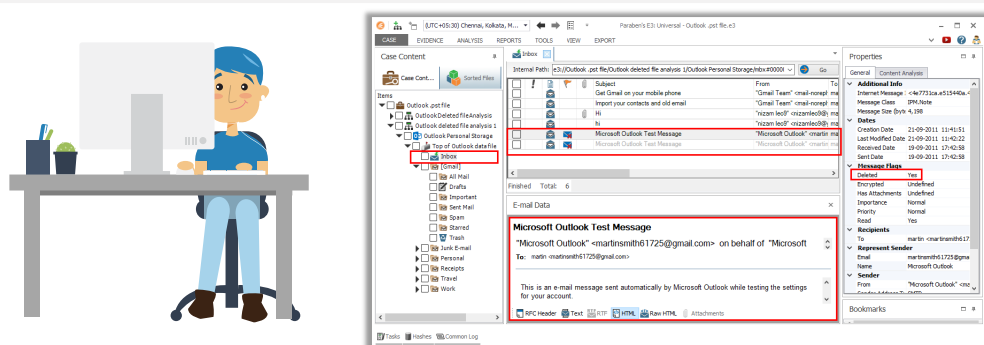
Recovering Deleted Email Messages from Outlook .pst Files Using Paraben's Electronic Evidence Examiner



Here the screenshot shows the **retrieval of two email messages** by Paraben's Electronic Email Examiner that have been deleted from Outlook local .pst files



You can see the recovered email's body, attachments, and its RFC headers and use the information for further analysis



Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Recovering Deleted Email Messages from Outlook .pst Files Using Paraben's Electronic Evidence Examiner

The screenshot below shows the retrieval of two email messages by Paraben's Electronic Email Examiner that have been deleted from Outlook local .pst files. You can see the recovered email's body, attachments, and its RFC headers and use the information for further analysis.

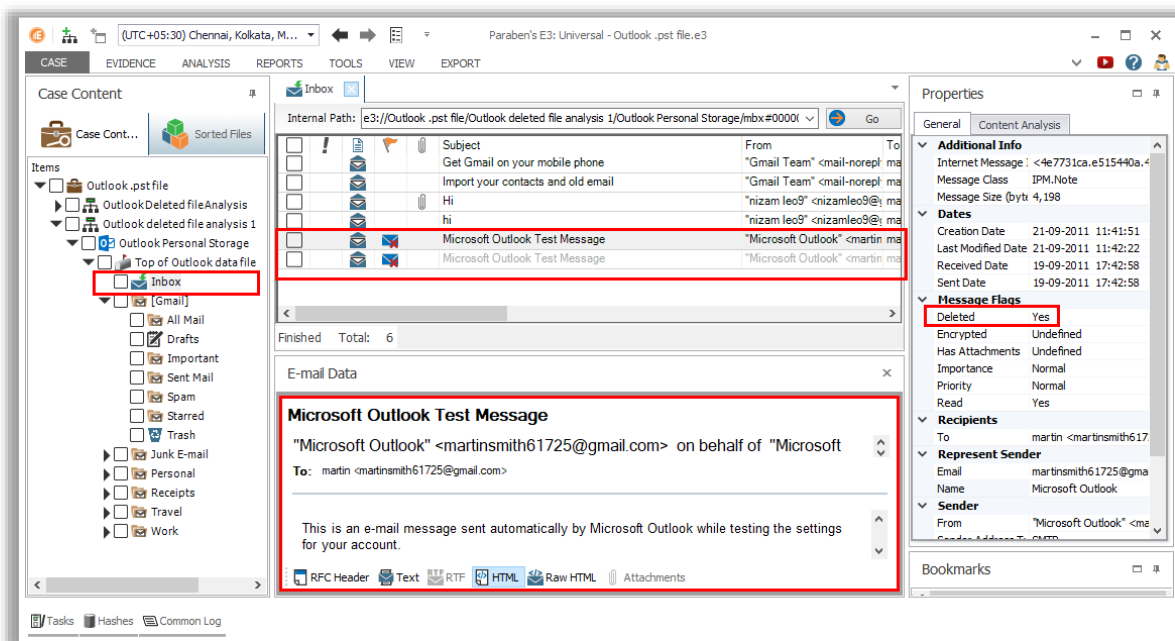


Figure 11.31: Recovery of deleted email messages from Outlook .pst files on Paraben's E3

Module Summary



- ➔ This module has discussed the email system
- ➔ It has discussed the components involved in email communication
- ➔ It has also discussed in detail the parts of an email message
- ➔ Finally, this module ended with a detailed discussion on email crime investigation and its steps
- ➔ In the next module, we will discuss in detail on malware forensics

Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.

Module Summary

This module discussed the email system and the components involved in email communication. Furthermore, it discussed in detail the parts of an email message. Finally, this module presented a detailed discussion on email crime investigation and its steps.

In the next module, we will discuss malware forensics in detail.